

INTERNACIONAL ESTÁNDAR

ISO/CEI
27003

Segunda edición
2017-03

Tecnología de la información — Técnicas de seguridad — Sistemas de gestión de la seguridad de la información — Orientación

Tecnología de la información — Técnicas de seguridad — Sistemas
de gestión de la seguridad de la información — Directrices



Número de referencia
ISO/IEC 27003:2017(E)

© ISO/CEI 2017



DOCUMENTO PROTEGIDO POR DERECHOS DE AUTOR

© ISO/IEC 2017, Publicado en Suiza Todos los derechos

reservados. A menos que se especifique lo contrario, ninguna parte de esta publicación puede reproducirse ni utilizarse de ninguna forma ni por ningún medio, ya sea electrónico o mecánico, incluidas las fotocopias o la publicación en Internet o en una intranet, sin autorización previa por escrito. El permiso se puede solicitar a ISO en la dirección que se indica a continuación o al organismo miembro de ISO en el país del solicitante.

Oficina de derechos de
autor ISO Cap. de Blandonnet 8 • CP
401 CH-1214 Vernier, Ginebra, Suiza Tel. +41 22
749 01 11 Telefax +41 22 749 09 47

copyright@iso.org
www.iso.org

Contenido

Página

Prefacio.....	iv
Introducción.....	v
1 Alcance.....	1
2 Referencias normativas	1
3 Términos y definiciones	1
4 Contexto de la organización	1
4.1 Entender la organización y su contexto.....	1
4.2 Comprensión de las necesidades y expectativas de las partes interesadas	1
4.3 Determinación del alcance del sistema de gestión de seguridad de la información.....	1
4.4 Sistema de gestión de la seguridad de la información	6
Liderazgo.....	6
Liderazgo y compromiso de la organización.....	6.5.1
5 Política	8
5.3 Funciones, responsabilidades y autoridades de la organización	9
6.1 Acciones para abordar riesgos y oportunidades	10
General.....	10
6.1.1 Tratamiento de riesgos de seguridad de la información	12
6.1.2 Evaluación de riesgos de seguridad de la información	15
6 Objetivos y planificación de la seguridad de la información para lograrlos	18
7.1 Recursos	21
7.2 Competencia..	22
7.3 Concienciación	23
6.2 Comunicación	24
7 Información documentada	25
7.5.1 Generalidad.....	27
7.5.3 Control de documentos.....	28
7.5.4 Crear y actualizar información.....	28
8 Operación.....	29
8.1 Planificación y control operativo.....	29
8.2 Evaluación de riesgos de seguridad de la información	31
8.3 Tratamiento de riesgos de seguridad de la información	31
9 Evaluación del desempeño	32
9.1 Monitoreo, medición, análisis y evaluación	32
9.2 Auditoría interna.....	33
9.3 Revisión por la dirección.....	33
10 Mejora	37
10.1 No conformidad y acción correctiva	37
10.2 Mejora continua.....	40
Anexo A (informativo) Marco de políticas ..	42
Bibliografía.	4

Prefacio

ISO (Organización Internacional de Normalización) e IEC (Comisión Electrotécnica Internacional) forman el sistema especializado para la normalización mundial. Los organismos nacionales que son miembros de ISO o IEC participan en el desarrollo de Normas Internacionales a través de comités técnicos establecidos por la organización respectiva para tratar campos particulares de actividad técnica. Los comités técnicos de ISO e IEC colaboran en campos de interés mutuo. Otras organizaciones internacionales, gubernamentales y no gubernamentales, en coordinación con ISO e IEC, también participan en el trabajo. En el campo de la tecnología de la información, ISO e IEC han establecido un comité técnico conjunto, ISO/IEC JTC 1.

Los procedimientos utilizados para desarrollar este documento y los destinados a su posterior mantenimiento se describen en las Directivas ISO/IEC, Parte 1. En particular, se deben tener en cuenta los diferentes criterios de aprobación necesarios para los diferentes tipos de documentos. Este documento fue redactado de acuerdo con las reglas editoriales de las Directivas ISO/IEC, Parte 2 (ver www.iso.org/directives).

Se llama la atención sobre la posibilidad de que algunos de los elementos de este documento puedan ser objeto de derechos de patente. ISO e IEC no serán responsables de identificar ninguno o todos los derechos de patente. Los detalles de cualquier derecho de patente identificado durante el desarrollo del documento estarán en la Introducción y/o en la lista ISO de declaraciones de patentes recibidas (ver www.iso.org/patents).

Cualquier nombre comercial utilizado en este documento es información proporcionada para la comodidad de los usuarios y no constituye un respaldo.

Para obtener una explicación sobre la naturaleza voluntaria de las normas, el significado de los términos y expresiones específicos de ISO relacionados con la evaluación de la conformidad, así como información sobre la adhesión de ISO a los principios de la Organización Mundial del Comercio (OMC) en las Obstáculos técnicos al comercio (TBT), consulte el siguiente URL: www.iso.org/iso/foreword.html.

Este documento fue preparado por ISO/IEC JTC 1, Tecnología de la información, Subcomité SC 27, Técnicas de seguridad de TI.

Esta segunda edición de ISO/IEC 27003 cancela y reemplaza la primera edición (ISO/IEC 27003:2010), de la cual constituye una revisión menor.

Los principales cambios con respecto a la edición anterior son los siguientes:

- el alcance y el título se han cambiado para cubrir la explicación y orientación sobre los requisitos de, ISO/IEC 27001:2013 en lugar de la edición anterior (ISO/IEC 27001:2005);
- la estructura ahora está alineada con la estructura de ISO/IEC 27001:2013 para que sea más fácil para el usuario usarla junto con ISO/IEC 27001:2013;
- la edición anterior tenía un enfoque de proyecto con una secuencia de actividades. En cambio, esta edición brinda orientación sobre los requisitos, independientemente del orden en que se implementen.

Introducción

Este documento brinda orientación sobre los requisitos para un sistema de gestión de seguridad de la información (SGSI) como se especifica en ISO/IEC 27001 y proporciona recomendaciones ("debería"), posibilidades ("puede") y permisos ("puede") en relación con ellos. No es la intención de este documento proporcionar una guía general sobre todos los aspectos de la seguridad de la información.

[Las cláusulas 4 a 10](#) de este documento reflejan la estructura de ISO/IEC 27001:2013.

Este documento no agrega ningún requisito nuevo para un SGSI y sus términos y definiciones relacionados. Las organizaciones deben consultar las normas ISO/IEC 27001 e ISO/IEC 27000 para conocer los requisitos y las definiciones. Las organizaciones que implementan un SGSI no tienen la obligación de observar la guía de este documento.

Un SGSI enfatiza la importancia de las siguientes fases:

- comprender las necesidades de la organización y la necesidad de establecer una política de seguridad de la información y objetivos de seguridad de la información;
- evaluar los riesgos de la organización relacionados con la seguridad de la información;
- implementar y operar procesos de seguridad de la información, controles y otras medidas para tratar los riesgos;
- monitorear y revisar el desempeño y la efectividad del SGSI; y
- practicar la mejora continua.

Un SGSI, al igual que cualquier otro tipo de sistema de gestión, incluye los siguientes componentes clave:

una política;

b) personas con responsabilidades definidas;

c) procesos de gestión relacionados con:

- 1) establecimiento de políticas;
- 2) provisión de conciencia y competencia;
- 3) planificación;
- 4) implementación;
- 5) operación;
- 6) evaluación del desempeño;
- 7) revisión de la gestión; y
- 8) mejora; y

d) información documentada.

Un SGSI tiene componentes clave adicionales como:

e) evaluación de riesgos de seguridad de la información; y

f) tratamiento de riesgos de seguridad de la información, incluyendo la determinación e implementación de controles.

Este documento es genérico y pretende ser aplicable a todas las organizaciones, independientemente de su tipo, tamaño o naturaleza. La organización debe identificar qué parte de esta guía se aplica a ella de acuerdo con su contexto organizacional específico (ver ISO/IEC 27001:2013, Cláusula 4).

ISO/IEC 27003:2017(E)

Por ejemplo, alguna orientación puede ser más adecuada para organizaciones grandes, pero para organizaciones muy pequeñas (por ejemplo, con menos de 10 personas) parte de la orientación puede ser innecesaria o inapropiada.

Las descripciones de las Cláusulas 4 a 10 están estructuradas de la siguiente manera:

- Actividad requerida: presenta las actividades clave requeridas en la subcláusula correspondiente de ISO/IEC 27001;
- Explicación: explica lo que implican los requisitos de ISO/IEC 27001;
- Orientación: proporciona información más detallada o de apoyo para implementar la “actividad requerida”, incluidos ejemplos para la implementación; y
- Otra información: proporciona información adicional que puede ser considerada.

ISO/IEC 27003, ISO/IEC 27004 e ISO/IEC 27005 forman un conjunto de documentos que respaldan y brindan orientación sobre ISO/IEC 27001:2013. Entre estos documentos, ISO/IEC 27003 es un documento básico y completo que brinda orientación para todos los requisitos de ISO/IEC 27001, pero no tiene descripciones detalladas sobre “monitoreo, medición, análisis y evaluación” y gestión de riesgos de seguridad de la información. ISO/IEC 27004 e ISO/IEC 27005 se enfocan en contenidos específicos y brindan una guía más detallada sobre “monitoreo, medición, análisis y evaluación” y gestión de riesgos de seguridad de la información.

Hay varias referencias explícitas a la información documentada en ISO/IEC 27001. No obstante, una organización puede conservar información documentada adicional que determine necesaria para la eficacia de su sistema de gestión como parte de su respuesta a ISO/IEC 27001:2013, 7.5.1b). En estos casos, este documento utiliza la frase “La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).”

Tecnología de la información — Técnicas de seguridad — Sistemas de gestión de la seguridad de la información: orientación

1 Alcance

Este documento proporciona una explicación y orientación sobre ISO/IEC 27001:2013.

2 Referencias normativas

Los siguientes documentos se mencionan en el texto de tal manera que parte o la totalidad de su contenido constituye requisitos de este documento. Para las referencias con fecha, sólo se aplica la edición citada. Para las referencias sin fecha, se aplica la última edición del documento de referencia (incluidas las modificaciones).

ISO/IEC 27000:2016, Tecnología de la información. Técnicas de seguridad. Sistemas de gestión de la seguridad de la información. Visión general y vocabulario.

ISO/IEC 27001:2013, Tecnología de la información. Técnicas de seguridad. Sistemas de gestión de la seguridad de la información. Requisitos.

3 Términos y definiciones

A los efectos de este documento, se aplican los términos y definiciones proporcionados en ISO/IEC 27000:2016.

ISO e IEC mantienen bases de datos terminológicas para su uso en la normalización en las siguientes direcciones:

— Electropedia IEC: disponible en <http://www.electropedia.org/>

— Plataforma de navegación en línea de ISO: disponible en <http://www.iso.org/obp>

4 Contexto de la organización

4.1 Entender la organización y su contexto

Actividad requerida

La organización determina los problemas externos e internos relevantes para su propósito y que afectan su capacidad para lograr los resultados previstos del sistema de gestión de seguridad de la información (SGSI).

Explicación

Como función integral del SGSI, la organización se analiza continuamente a sí misma y al mundo que la rodea. Este análisis se ocupa de los problemas externos e internos que de alguna manera afectan la seguridad de la información y cómo se puede gestionar la seguridad de la información, y que son relevantes para los objetivos de la organización.

El análisis de estos temas tiene tres propósitos:

- comprender el contexto para decidir el alcance del SGSI;
- analizar el contexto para determinar riesgos y oportunidades; y
- asegurar que el SGSI se adapte a los cambiantes problemas externos e internos.

ISO/IEC 27003:2017(E)

Los problemas externos son aquellos que están fuera del control de la organización. Esto a menudo se conoce como el entorno de la organización. El análisis de este entorno puede incluir los siguientes aspectos:

- a) sociales y culturales;
- b) políticas, jurídicas, normativas y reglamentarias;
- c) financiera y macroeconómica;
- d) tecnológico;
- e) naturales; y
- f) competitivo.

Estos aspectos del entorno de la organización presentan continuamente problemas que afectan la seguridad de la información y cómo se puede gestionar la seguridad de la información. Los asuntos externos relevantes dependen de las prioridades y la situación específicas de la organización.

Por ejemplo, los problemas externos para una organización específica pueden incluir:

- g) las implicaciones legales del uso de un servicio de TI subcontratado (aspecto legal);
- h) características de la naturaleza en términos de posibilidad de desastres tales como incendios, inundaciones y terremotos (aspecto natural);
- i) avances técnicos de herramientas de hacking y uso de criptografía (aspecto tecnológico); y
- j) la demanda general de los servicios de la organización (aspectos sociales, culturales o financieros).

Los asuntos internos están sujetos al control de la organización. El análisis de los problemas internos puede incluir los siguientes aspectos:

- k) la cultura de la organización;
- l) políticas, objetivos y las estrategias para alcanzarlos;
- m) gobernanza, estructura organizativa, funciones y responsabilidades;
- n) normas, directrices y modelos adoptados por la organización;
- o) relaciones contractuales que pueden afectar directamente a los procesos de la organización incluidos en el alcance del SGSI;
- p) procesos y procedimientos;
- q) las capacidades, en términos de recursos y conocimientos (por ejemplo, capital, tiempo, personas, procesos, sistemas y tecnologías);
- r) infraestructura física y medio ambiente;
- s) sistemas de información, flujos de información y procesos de toma de decisiones (tanto formales como informal); y
- t) auditorías anteriores y resultados de evaluaciones de riesgos anteriores.

Los resultados de esta actividad se utilizan en [4.3](#), [6.1](#) y [9.3](#).

Guía

Sobre la base de una comprensión del propósito de la organización (por ejemplo, en referencia a su declaración de misión o plan de negocios), así como los resultados previstos del SGSI de la organización, la organización debería:

- revisar el entorno externo para identificar problemas externos relevantes; y

— revisar los aspectos internos para identificar cuestiones internas relevantes.

Para identificar problemas relevantes, se puede hacer la siguiente pregunta: ¿Cómo afecta una determinada categoría de problemas (ver a) a t) arriba a los objetivos de seguridad de la información? Tres ejemplos de problemas internos sirven como ilustración:

Ejemplo 1 sobre gobernanza y estructura organizativa (véase el punto m)): Al establecer un SGSI, se deben tener en cuenta las estructuras organizativas y de gobernanza ya existentes. Como ejemplo, la organización puede modelar la estructura de su SGSI basándose en la estructura de otros sistemas de gestión existentes y puede combinar funciones comunes, como la revisión y auditoría de la gestión.

Ejemplo 2 sobre política, objetivos y estrategias (ver punto l)): Un análisis de las políticas, objetivos y estrategias existentes puede indicar lo que la organización pretende lograr y cómo los objetivos de seguridad de la información pueden alinearse con los objetivos comerciales para garantizar resultados exitosos.

Ejemplo 3 sobre sistemas de información y flujos de información (ver ítem s)): Al determinar problemas internos, la organización debe identificar, con suficiente nivel de detalle, los flujos de información entre sus diversos sistemas de información.

Dado que tanto los problemas externos como los internos cambiarán con el tiempo, los problemas y su influencia en el alcance, las limitaciones y los requisitos del SGSI deben revisarse periódicamente.

La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).

Otra información

En ISO/IEC 27000, la definición de “organización” tiene una nota que establece que: “El concepto de organización incluye, entre otros, comerciante único, compañía, corporación, firma, empresa, autoridad, sociedad, organización benéfica o institución, o parte o combinación de los mismos, sean o no sociedades anónimas, públicas o privadas.” Algunos de estos ejemplos son entidades legales completas, mientras que otros no lo son.

Hay cuatro casos:

- 1) la organización es una entidad legal o administrativa (p. ej., comerciante único, compañía, corporación, firma, empresa, autoridad, sociedad, caridad o institución, ya sea constituida o no, pública o privada);
- 2) la organización es un subconjunto de una entidad legal o administrativa (por ejemplo, parte de una empresa, corporación, empresa);
- 3) la organización es un conjunto de entidades legales o administrativas (por ejemplo, un consorcio de comerciantes individuales, empresas, corporaciones, firmas); y
- 4) la organización es un conjunto de subconjuntos de entidades legales o administrativas (por ejemplo, clubes, asociaciones comerciales).

4.2 Comprender las necesidades y expectativas de las partes interesadas

Actividad requerida

La organización determina las partes interesadas relevantes para el SGSI y sus requisitos relevantes para la seguridad de la información.

Explicación

Parte interesada es un término definido (ver ISO/IEC 27000:2016, 2.41) que se refiere a personas u organizaciones que pueden afectar, verse afectadas o percibirse como afectadas por una decisión o actividad de la organización. Las partes interesadas se pueden encontrar tanto fuera como dentro de la organización y pueden tener necesidades, expectativas y requisitos específicos para la seguridad de la información de la organización.

ISO/IEC 27003:2017(E)

Las partes interesadas externas pueden incluir:

- a) reguladores y legisladores;
- b) accionistas, incluidos propietarios e inversores;
- c) proveedores, incluidos subcontratistas, consultores y socios externos;
- d) asociaciones industriales;
- e) competidores;
- f) clientes y consumidores; y
- g) grupos activistas.

Las partes interesadas internas pueden incluir:

- h) los responsables de la toma de decisiones, incluida la alta dirección;
- i) propietarios de procesos, propietarios de sistemas y propietarios de información;
- j) funciones de apoyo como TI o Recursos Humanos;
- k) empleados y usuarios; y
- l) profesionales de la seguridad de la información.

Los resultados de esta actividad se utilizan en [4.3](#) y [6.1](#).

Guía

Se deben tomar los siguientes pasos:

- identificar partes interesadas externas;
- identificar las partes interesadas internas; y
- identificar los requisitos de las partes interesadas.

A medida que las necesidades, expectativas y requisitos de las partes interesadas cambian con el tiempo, estos cambios y su influencia en el alcance, las limitaciones y los requisitos del SGSI deben revisarse periódicamente.

La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).

Otra información

Ninguna otra información.

4.3 Determinación del alcance del sistema de gestión de seguridad de la información

Actividad requerida

La organización determina los límites y la aplicabilidad del SGSI para establecer su alcance.

Explicación

El alcance define dónde y para qué es exactamente aplicable el SGSI y dónde y para qué no lo es.

Por lo tanto, establecer el alcance es una actividad clave que determina la base necesaria para todas las demás actividades en la implementación del SGSI. Por ejemplo, la evaluación y el tratamiento del riesgo, incluida la determinación de los controles, no producirán resultados válidos sin tener una comprensión precisa de

donde es exactamente aplicable el SGSI. El conocimiento preciso de los límites y la aplicabilidad del SGSI y las interfaces y dependencias entre la organización y otras organizaciones también es fundamental. Cualquier modificación posterior del alcance puede resultar en un esfuerzo y costos adicionales considerables.

Los siguientes factores pueden afectar la determinación del alcance:

- a) los problemas externos e internos descritos en 4.1; —
- b) los interesados y sus requisitos que se determinen de acuerdo con ISO/IEC 27001:2013, 4.2;
- c) la preparación de las actividades comerciales para ser incluidas como parte de la cobertura del SGSI;
- d) todas las funciones de soporte, es decir, las funciones que son necesarias para respaldar estas actividades comerciales (por ejemplo, gestión de recursos humanos ; servicios de TI y aplicaciones de software; gestión de instalaciones de edificios, zonas físicas, servicios esenciales y utilidades); y
- e) todas las funciones que se subcontratan a otras partes dentro de la organización o a proveedores.

El alcance de un SGSI puede ser muy diferente de una implementación a otra. Por ejemplo, el alcance puede incluir:

- uno o más procesos específicos;
- una o más funciones específicas;
- uno o más servicios específicos;
- una o más secciones o ubicaciones específicas;
- una entidad legal completa; y
- toda una entidad administrativa y uno o más de sus proveedores.

Guía

Para establecer el alcance de un SGSI, se puede seguir un enfoque de varios pasos:

- f) determinar el alcance preliminar: esta actividad debe ser realizada por una pequeña, pero representativa grupo de representantes de la dirección;
- g) determinar el alcance perfeccionado: deben revisarse las unidades funcionales dentro y fuera del alcance preliminar, posiblemente seguido de la inclusión o exclusión de algunas de estas unidades funcionales para reducir el número de interfaces a lo largo de los límites. Al refinar el alcance preliminar, se deben considerar todas las funciones de soporte que sean necesarias para respaldar las actividades comerciales incluidas en el alcance;
- h) determinar el alcance final: el alcance refinado debe ser evaluado por toda la gerencia dentro del alcance refinado. Si es necesario, debe ajustarse y luego describirse con precisión; y
- i) aprobación del alcance: la información documentada que describe el alcance debe ser aprobada formalmente por la alta dirección.

La organización también debe considerar las actividades con impacto en el SGSI o las actividades que se subcontratan, ya sea a otras partes dentro de la organización o a proveedores independientes. Para tales actividades, se deben identificar las interfaces (físicas, técnicas y organizacionales) y su influencia en el alcance.

La información documentada que describe el alcance debe incluir:

- j) el alcance organizacional, los límites y las interfaces;

ISO/IEC 27003:2017(E)

- k) el alcance, los límites y las interfaces de las tecnologías de la información y las comunicaciones; y
- l) el alcance físico, los límites y las interfaces.

Otra información

Ninguna otra información.

4.4 Sistema de gestión de seguridad de la información

Actividad requerida

La organización establece, implementa, mantiene y mejora continuamente el SGSI.

Explicación

ISO/IEC 27001:2013, 4.4 establece el requisito central para establecer, implementar, mantener y mejorar continuamente un SGSI. Mientras que las otras partes de ISO/IEC 27001 describen los elementos requeridos de un SGSI, 4.4 obliga a la organización a garantizar que se cumplan todos los elementos necesarios para establecer, implementar, mantener y mejorar continuamente el SGSI.

Guía

Sin orientación específica.

Otra información

Ninguna otra información.

5 Liderazgo

5.1 Liderazgo y compromiso

Actividad requerida

La alta dirección demuestra liderazgo y compromiso con respecto al SGSI.

Explicación

El liderazgo y el compromiso son esenciales para un SGSI eficaz.

La alta dirección se define (ver ISO/IEC 27000) como una persona o grupo de personas que dirige y controla la organización del SGSI al más alto nivel, es decir, la alta dirección tiene la responsabilidad general del SGSI. Esto significa que la alta dirección dirige el SGSI de forma similar a otras áreas de la organización, por ejemplo, la forma en que se asignan y supervisan los presupuestos. La alta dirección puede delegar autoridad en la organización y proporcionar recursos para realizar actividades relacionadas con la seguridad de la información y el SGSI, pero aún conserva la responsabilidad general.

Como ejemplo, la organización que implementa y opera el SGSI puede ser una unidad de negocios dentro de una organización más grande. En este caso, la alta dirección es la persona o grupo de personas que dirige y controla esa unidad de negocio.

La alta dirección también participa en la revisión por la dirección (ver [9.3](#)) y promueve la mejora continua (ver [10.2](#)).

Guía

La alta dirección debe proporcionar liderazgo y mostrar compromiso a través de lo siguiente:

- a) la alta dirección debe asegurarse de que la política de seguridad de la información y los objetivos de seguridad de la información estén establecidos y sean compatibles con la dirección estratégica de la organización;

b) la alta dirección debe asegurarse de que los requisitos y controles del SGSI estén integrados en los procesos de la organización. La forma en que esto se logra debe adaptarse al contexto específico de la organización. Por ejemplo, una organización que ha designado propietarios de procesos puede delegar la responsabilidad de implementar los requisitos aplicables a estas personas o grupos de personas. También puede ser necesario el apoyo de la alta dirección para superar la resistencia de la organización a los cambios en los procesos y controles;

c) la alta dirección debe garantizar la disponibilidad de recursos para un SGSI eficaz. Los recursos son necesarios para el establecimiento del SGSI, su implementación, mantenimiento y mejora, así como para implementar controles de seguridad de la información. Los recursos necesarios para el SGSI incluyen:

1) recursos financieros;

2) personal;

3) instalaciones; y

4) infraestructura técnica.

Los recursos necesarios dependen del contexto de la organización, como el tamaño, la complejidad y los requisitos internos y externos. La revisión por la dirección debe proporcionar información que indique si los recursos son adecuados para la organización;

d) la alta dirección debe comunicar la necesidad de gestión de la seguridad de la información en la organización y la necesidad de cumplir con los requisitos del SGSI. Esto se puede hacer dando ejemplos prácticos que ilustren cuál es la necesidad real en el contexto de la organización y comunicando los requisitos de seguridad de la información;

e) la alta dirección debe asegurarse de que el SGSI logre los resultados previstos apoyando la implementación de todos los procesos de gestión de la seguridad de la información y, en particular, solicitando y revisando informes sobre el estado y la eficacia del SGSI (véase 5.3 b)). Dichos informes pueden derivarse de mediciones (ver 6.2 b) y 9.1 a)), revisiones de gestión e informes de auditoría.

La alta dirección también puede establecer objetivos de desempeño para el personal clave involucrado con el SGSI;

f) la alta dirección debe dirigir y apoyar a las personas de la organización directamente involucradas con la seguridad de la información y el SGSI. No hacerlo puede tener un impacto negativo en la efectividad del SGSI. Los comentarios de la alta dirección pueden incluir cómo las actividades planificadas se alinean con las necesidades estratégicas de la organización y también para priorizar diferentes actividades en el SGSI;

g) la alta dirección debe evaluar las necesidades de recursos durante las revisiones de gestión y establecer objetivos para la mejora continua y para monitorear la efectividad de las actividades planificadas; y

h) la alta dirección debe apoyar a las personas a las que se les han asignado funciones y responsabilidades relacionadas con la gestión de la seguridad de la información, para que estén motivadas y sean capaces de dirigir y apoyar las actividades de seguridad de la información dentro de su área.

En los casos en que la organización que implementa y opera un SGSI es parte de una organización más grande, el liderazgo y el compromiso se pueden mejorar mediante la participación de la persona o grupo de personas que controla y dirige la organización más grande. Si entienden lo que implica la implementación de un SGSI, pueden brindar apoyo a la alta dirección dentro del alcance del SGSI y ayudarlos a proporcionar liderazgo y demostrar compromiso con el SGSI. Por ejemplo, si las partes interesadas fuera del alcance del SGSI participan en la toma de decisiones sobre los objetivos de seguridad de la información y los criterios de riesgo y se les informa sobre los resultados de seguridad de la información producidos por el SGSI, sus decisiones sobre la asignación de recursos se pueden alinear con los requisitos del SGSI. SGSI.

Otra información

Ninguna otra información.

ISO/IEC 27003:2017(E)

5.2 Política

Actividad requerida

La alta dirección establece una política de seguridad de la información.

Explicación

La política de seguridad de la información describe la importancia estratégica del SGSI para la organización y está disponible como información documentada. La política dirige las actividades de seguridad de la información en la organización.

La política establece cuáles son las necesidades de seguridad de la información en el contexto real de la organización.

Guía

La política de seguridad de la información debe contener declaraciones de intención y dirección breves y de alto nivel con respecto a la seguridad de la información. Puede ser específico del alcance de un SGSI o puede tener una cobertura más amplia.

Todas las demás políticas, procedimientos, actividades y objetivos relacionados con la seguridad de la información deben estar alineados con la política de seguridad de la información.

La política de seguridad de la información debe reflejar la situación empresarial, la cultura, los problemas y las preocupaciones de la organización en relación con la seguridad de la información. El alcance de la política de seguridad de la información debe estar de acuerdo con el propósito y la cultura de la organización y debe buscar un equilibrio entre la facilidad de lectura y la exhaustividad. Es importante que los usuarios de la política puedan identificarse con la dirección estratégica de la política.

La política de seguridad de la información puede incluir objetivos de seguridad de la información para la organización o describir el marco de cómo se establecen los objetivos de seguridad de la información (es decir, quién los establece para el SGSI y cómo deben implementarse dentro del alcance del SGSI). Por ejemplo, en organizaciones muy grandes, los objetivos de alto nivel deben ser establecidos por la alta dirección de toda la organización, luego, de acuerdo con un marco establecido en la política de seguridad de la información, los objetivos deben detallarse de manera que den un sentido de dirección. a todas las partes interesadas.

La política de seguridad de la información debe contener una declaración clara de la alta dirección sobre su compromiso de satisfacer los requisitos relacionados con la seguridad de la información.

La política de seguridad de la información debe contener una declaración clara de que la alta dirección apoya la mejora continua en todas las actividades. Es importante establecer este principio en la política, para que las personas dentro del alcance del SGSI lo conozcan.

La política de seguridad de la información debe comunicarse a todas las personas dentro del alcance del SGSI. Por tanto, su formato y lenguaje debe ser adecuado para que sea fácilmente comprensible para todos los destinatarios.

La alta dirección debe decidir a qué partes interesadas debe comunicarse la política. La política de seguridad de la información se puede escribir de tal manera que sea posible comunicarla a las partes interesadas externas relevantes fuera de la organización. Ejemplos de tales partes interesadas externas son clientes, proveedores, contratistas, subcontratistas y reguladores. Si la política de seguridad de la información se pone a disposición de partes interesadas externas, no debe incluir información confidencial.

La política de seguridad de la información puede ser una política independiente separada o estar incluida en una política integral, que cubra múltiples temas del sistema de gestión dentro de la organización (p. ej., calidad, medio ambiente y seguridad de la información).

La política de seguridad de la información debe estar disponible como información documentada. Los requisitos de ISO/IEC 27001 no implican ninguna forma específica para esta información documentada y, por lo tanto, depende de la organización decidir qué forma es la más apropiada. Si la organización tiene una plantilla estándar para políticas, el formulario de la política de seguridad de la información debe usar esta plantilla.

Otra información

Se puede encontrar más información sobre políticas relacionadas con la seguridad de la información en ISO/IEC 27002.

Se puede encontrar más información sobre la relación entre la política de seguridad de la información y otras políticas en un marco de políticas en el [Anexo A](#).

5.3 Funciones, responsabilidades y autoridades de la organización

Actividad requerida

La alta dirección se asegura de que las responsabilidades y autoridades de los roles relevantes para la seguridad de la información se asignen y comuniquen en toda la organización.

Explicación

La alta dirección se asegura de que se asignen y comuniquen las funciones y responsabilidades, así como las autoridades necesarias relevantes para la seguridad de la información.

El propósito de este requisito es asignar responsabilidades y autoridades para garantizar la conformidad del SGSI con los requisitos de la norma ISO/IEC 27001 y garantizar la presentación de informes sobre el desempeño del SGSI a la alta dirección.

Guía

La alta dirección debe asegurarse regularmente de que las responsabilidades y autoridades para el SGSI se asignen de manera que el sistema de gestión cumpla con los requisitos establecidos en ISO/IEC 27001. La alta dirección no necesita asignar todas las funciones, responsabilidades y autoridades, pero debe delegar adecuadamente la autoridad. para hacer esto. La alta dirección debe aprobar las principales funciones, responsabilidades y autoridades del SGSI.

Se deben asignar responsabilidades y autoridades relacionadas con las actividades de seguridad de la información. Actividades incluidas:

- a) coordinar el establecimiento, implementación, mantenimiento, informes de desempeño y mejora del SGSI;
- b) asesorar en la evaluación y tratamiento de riesgos de seguridad de la información;
- c) diseñar procesos y sistemas de seguridad de la información;
- d) establecer normas relativas a la determinación, configuración y funcionamiento de la seguridad de la información control S;
- e) gestionar incidentes de seguridad de la información; y
- f) revisar y auditar el SGSI.

Más allá de los roles específicamente relacionados con la seguridad de la información, las responsabilidades y autoridades de seguridad de la información relevantes deben incluirse dentro de otros roles. Por ejemplo, las responsabilidades de seguridad de la información se pueden incorporar en los roles de:

- g) propietarios de la información;
- h) propietarios de procesos;
- i) propietarios de activos (por ejemplo, propietarios de aplicaciones o infraestructura);
- j) propietarios de riesgos;
- k) funciones o personas de coordinación de la seguridad de la información (esta función particular normalmente es una función de apoyo en el SGSI);

ISO/IEC 27003:2017(E)

l) directores de proyectos;

m) gerentes de línea; y

n) usuarios de la información.

La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).

Otra información

Ninguna otra información.

6 Planificación

6.1 Acciones para abordar riesgos y oportunidades

6.1.1 Generalidades

Descripción general

ISO/IEC 27001:2013, 6.1 se ocupa de la planificación de acciones para abordar todos los tipos de riesgos y oportunidades que son relevantes para el SGSI. Esto incluye la evaluación de riesgos y la planificación de riesgos de tratamiento.

La estructura de ISO/IEC 27001 subdivide los riesgos en dos categorías durante la planificación:

- a) riesgos y oportunidades relevantes para los resultados previstos del SGSI en su conjunto; y
- b) riesgos de seguridad de la información relacionados con la pérdida de confidencialidad, integridad y disponibilidad de la información dentro del alcance del SGSI.

La primera categoría debe manejarse de acuerdo con los requisitos especificados en ISO/IEC 27001:2013, 6.1.1 (general). Los riesgos que entran en esta categoría pueden ser riesgos relacionados con el propio SGSI, la definición del alcance del SGSI, el compromiso de la alta dirección con la seguridad de la información, los recursos para operar el SGSI, etc. Las oportunidades que entran en esta categoría pueden ser oportunidades relacionadas con los resultados.) del SGSI, el valor comercial de un SGSI, la eficiencia de los procesos operativos del SGSI y los controles de seguridad de la información, etc.

La segunda categoría consiste en todos los riesgos que se relacionan directamente con la pérdida de confidencialidad, integridad y disponibilidad de la información dentro del alcance del SGSI. Estos riesgos deben manejarse de acuerdo con 6.1.2 (evaluación de riesgos de seguridad de la información) y 6.1.3 (tratamiento de riesgos de seguridad de la información).

Las organizaciones pueden optar por utilizar diferentes técnicas para cada categoría.

La subdivisión de los requisitos para abordar los riesgos se puede explicar de la siguiente manera:

- fomenta la compatibilidad con otras normas de sistemas de gestión para aquellas organizaciones que cuentan con sistemas de gestión integrados para diferentes aspectos como la calidad, el medio ambiente y la seguridad de la información;
- requiere que la organización defina y aplique procesos completos y detallados para la evaluación y tratamiento de riesgos de seguridad de la información; y
- enfatiza que la gestión de riesgos de seguridad de la información es el elemento central de un SGSI.

ISO/IEC 27001:2013, 6.1.1 utiliza las expresiones 'determinar los riesgos y oportunidades' y 'abordar estos riesgos y oportunidades'. La palabra "determinar" puede considerarse equivalente a la palabra "evaluar" utilizada en ISO/IEC 27001:2013, 6.1.2 (es decir, identificar, analizar y evaluar). De manera similar, la palabra "dirección" puede considerarse equivalente a la palabra "tratar" utilizada en ISO/IEC 27001:2013, 6.1.3.

Actividad requerida

Al planificar el SGSI, la organización determina los riesgos y las oportunidades teniendo en cuenta las cuestiones a las que se hace referencia en el apartado 4.1 y los requisitos a los que se hace referencia en el apartado 4.2.

Explicación

Para los riesgos y oportunidades relevantes para los resultados previstos del SGSI, la organización los determina con base en cuestiones internas y externas (ver 4.1) y requisitos de las partes interesadas (ver 4.2). Luego, la organización planifica su SGSI para: —

- a) asegurarse de que el SGSI entregue los resultados previstos, por ejemplo, que los riesgos de seguridad de la información sean conocidos por los propietarios del riesgo y tratados a un nivel aceptable;
- b) prevenir o reducir los efectos no deseados de los riesgos relacionados con los resultados previstos del SGSI; y
- c) lograr la mejora continua (ver 10.2), por ejemplo, a través de mecanismos apropiados para detectar y corregir debilidades en los procesos de gestión o aprovechar oportunidades para mejorar la seguridad de la información.

Los riesgos relacionados con a) anterior podrían ser procesos y responsabilidades poco claros, poca conciencia entre los empleados, compromiso deficiente de la gerencia, etc. Los riesgos relacionados con b) anterior podrían ser una mala gestión de riesgos o poca conciencia de los riesgos. Los riesgos relacionados con c) anterior podrían ser una gestión deficiente de la documentación y los procesos del SGSI.

Cuando una organización busca oportunidades en sus actividades, estas actividades afectan el contexto de la organización (ISO/IEC 27001:2013, 4.1) o las necesidades y expectativas de las partes interesadas (ISO/IEC 27001:2013, 4.2), y pueden cambiar los riesgos para la organización. Ejemplos de tales oportunidades pueden ser: enfocar su negocio en algunas áreas de productos o servicios, establecer una estrategia de marketing para algunas regiones geográficas o expandir las asociaciones comerciales con otras organizaciones.

También existen oportunidades en las mejoras continuas de los procesos y la documentación del SGSI, junto con la evaluación de los resultados previstos entregados por el SGSI. Por ejemplo, la consideración de un SGSI relativamente nuevo a menudo da como resultado la identificación de oportunidades para perfeccionar los procesos aclarando las interfaces, reduciendo los gastos generales administrativos, eliminando partes de los procesos que no son rentables, perfeccionando la documentación e introduciendo nueva tecnología de la información.

La planificación en 6.1.1 incluye la determinación de:

- d) acciones para abordar los riesgos y oportunidades; y
- e) la forma de:
 - 1) integrar e implementar estas acciones en los procesos del SGSI; y
 - 2) evaluar la efectividad de estas acciones.

Guía

La organización debería:

- f) determinar los riesgos y oportunidades que puedan afectar el logro de las metas descritas en a), b) y c), considerando los aspectos a que se refiere el 4.1 y los requisitos a que se refiere el 4.2; y —
- g) desarrollar un plan para implementar las acciones determinadas y evaluar la efectividad de esas acciones; las acciones deben planificarse considerando la integración de los procesos de seguridad de la información y la documentación en las estructuras existentes; todas estas acciones están vinculadas con los objetivos de seguridad de la información (6.2) contra los cuales se evalúan y tratan los riesgos de seguridad de la información (ver 6.1.2 y 6.1.3). —

El requisito general para mejorar continuamente el SGSI establecido en ISO/IEC 27001:2013, 10.2 está respaldado por el requisito para lograr la mejora continua dado en 6.1.1 con otros requisitos relevantes de ISO/IEC 27001:2013, 5.1 g), 5.2 d), 9.1, 9.2 y 9.3.

ISO/IEC 27003:2017(E)

Las acciones requeridas en 6.1.1 pueden ser diferentes para niveles estratégicos, tácticos y operativos, para diferentes sitios o para diferentes servicios o sistemas.

Se pueden tomar varios enfoques para cumplir con los requisitos de 6.1.1, dos de los cuales son:

- considerando los riesgos y oportunidades asociados con la planificación, implementación y operación del SGSI por separado de los riesgos de seguridad de la información; y
- considerando todos los riesgos simultáneamente.

Una organización que está integrando un SGSI en un sistema de gestión establecido puede encontrar que los requisitos de 6.1.1 se cumplen con la metodología de planificación comercial existente de la organización. Cuando este sea el caso, se debe tener cuidado para verificar que la metodología cubra todos los requisitos de 6.1.1.

La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).

Otra información

Puede encontrar más información sobre la gestión de riesgos en la norma ISO 31000.

NOTA El término “riesgo” se define como el “efecto de la incertidumbre sobre los objetivos” (ver ISO/IEC 27000:2016, 2.68).

6.1.2 Evaluación de riesgos de seguridad de la información

Actividad requerida

La organización define y aplica un proceso de evaluación de riesgos de seguridad de la información.

Explicación

La organización define un proceso de evaluación de riesgos de seguridad de la información que:

a) establece y mantiene:

- 1) los criterios de aceptación del riesgo; y
- 2) criterios para realizar evaluaciones de riesgos de seguridad de la información, que pueden incluir criterios para evaluar la consecuencia y probabilidad, y reglas para la determinación del nivel de riesgo; y

b) asegura que las evaluaciones de riesgos de seguridad de la información repetidas produzcan resultados consistentes, válidos y resultados comparables.

El proceso de evaluación de riesgos de seguridad de la información se define luego a lo largo de los siguientes subprocesos:

c) identificación de riesgos de seguridad de la información:

- 1) identificar los riesgos asociados con la pérdida de confidencialidad, integridad y disponibilidad de la información dentro del alcance del SGSI; y
- 2) identificar a los propietarios de los riesgos asociados con estos riesgos, es decir, identificar y designar personas con la autoridad y responsabilidad apropiadas para gestionar los riesgos identificados.

d) análisis de los riesgos de seguridad de la información:

- 1) evaluar las posibles consecuencias en caso de que se materialicen los riesgos identificados, por ejemplo, impactos comerciales directos, como pérdidas monetarias, o impactos comerciales indirectos, como daños a la reputación. Las consecuencias evaluadas se pueden informar con valores cuantitativos o cualitativos;
- 2) evaluar la probabilidad realista de ocurrencia de los riesgos identificados, con criterios cuantitativos (es decir, probabilidad o frecuencia) o valores cualitativos; y

- 3) determinar los niveles de riesgo identificado como una combinación predefinida de consecuencias evaluadas y probabilidades evaluadas; y

e) evaluación de los riesgos de seguridad de la información:

- 1) comparar los resultados del análisis de riesgos con los criterios de aceptación de riesgos establecidos anteriormente; y
- 2) priorizar los riesgos analizados para el tratamiento del riesgo, es decir, determinar la urgencia del tratamiento de los riesgos que se consideran inaceptables y secuenciar si varios riesgos necesitan tratamiento.

Luego se aplica el proceso de evaluación de riesgos de seguridad de la información.

Todos los pasos del proceso de evaluación de riesgos de seguridad de la información (6.1.2 a) a e)), así como los resultados de su aplicación, son retenidos por la organización como información documentada.

Guía

Orientación sobre el establecimiento de criterios de riesgo (6.1.2 a))

Los criterios de riesgo de seguridad de la información deben establecerse teniendo en cuenta el contexto de la organización y los requisitos de las partes interesadas y deben definirse de acuerdo con las preferencias de riesgo y las percepciones de riesgo de la alta dirección, por un lado, y deben permitir un proceso de gestión de riesgos factible y apropiado, por el otro. mano.

Los criterios de riesgo de seguridad de la información deben establecerse en relación con los resultados previstos del SGSI.

De acuerdo con ISO/IEC 27001:2013, 6.1.2 a), se deben establecer criterios relacionados con la evaluación de riesgos de seguridad de la información que consideren la evaluación de la probabilidad y las consecuencias. Además, deben establecerse criterios de aceptación del riesgo.

Después de establecer criterios para evaluar las consecuencias y probabilidades de los riesgos de seguridad de la información, la organización también debe establecer un método para combinarlos a fin de determinar un nivel de riesgo. Las consecuencias y probabilidades pueden expresarse de manera cualitativa, cuantitativa o semicuantitativa.

Los criterios de aceptación del riesgo se relacionan con la evaluación del riesgo (en su fase de evaluación, cuando la organización debe comprender si un riesgo es aceptable o no), y las actividades de tratamiento del riesgo (cuando la organización debe comprender si el tratamiento del riesgo propuesto es suficiente para alcanzar un nivel aceptable de riesgo).

Los criterios de aceptación de riesgos pueden basarse en un nivel máximo de riesgos aceptables, en consideraciones de costo-beneficio o en las consecuencias para la organización.

Los criterios de aceptación del riesgo deben ser aprobados por la dirección responsable.

Orientación sobre la producción de resultados de evaluación consistentes, válidos y comparables (6.1.2 b))

El proceso de evaluación de riesgos debe basarse en métodos y herramientas diseñados con suficiente detalle para que conduzca a resultados consistentes, válidos y comparables.

Cualquiera que sea el método elegido, el proceso de evaluación de riesgos de seguridad de la información debe garantizar que:

- se consideran todos los riesgos, con el nivel de detalle necesario;
- sus resultados sean consistentes y reproducibles (es decir, la identificación de riesgos, su análisis y su evaluación puedan ser entendidos por un tercero y los resultados sean los mismos cuando diferentes personas evalúen los riesgos en el mismo contexto); y
- los resultados de evaluaciones de riesgos repetidas son comparables (es decir, es posible comprender si los niveles de riesgo aumentan o disminuyen).

Las inconsistencias o discrepancias en los resultados cuando se repite todo o parte del proceso de evaluación de riesgos de seguridad de la información pueden indicar que el método de evaluación de riesgos elegido no es adecuado.

ISO/IEC 27003:2017(E)

Orientación sobre la identificación de riesgos de seguridad de la información (6.1.2 c))

La identificación de riesgos es el proceso de encontrar, reconocer y describir los riesgos. Esto implica la identificación de las fuentes de riesgo, los eventos, sus causas y sus posibles consecuencias.

El objetivo de la identificación de riesgos es generar una lista completa de riesgos basada en aquellos eventos que podrían crear, mejorar, prevenir, degradar, acelerar o retrasar el logro de los objetivos de seguridad de la información.

Dos enfoques se utilizan comúnmente para la identificación de riesgos de seguridad de la información:

- enfoque basado en eventos: considera las fuentes de riesgo de forma genérica. Los eventos considerados pueden haber ocurrido en el pasado o pueden anticiparse para el futuro. En el primer caso pueden involucrar datos históricos, en el segundo caso pueden basarse en análisis teóricos y opiniones de expertos; y
- enfoque basado en la identificación de activos, amenazas y vulnerabilidades: considera dos tipos diferentes de fuentes de riesgo: activos con sus vulnerabilidades intrínsecas y amenazas. Los eventos potenciales considerados aquí son formas de cómo las amenazas podrían explotar una cierta vulnerabilidad de un activo para impactar los objetivos de la organización.

Ambos enfoques son coherentes con los principios y las directrices genéricas sobre evaluación de riesgos de la norma ISO 31000.

Se pueden utilizar otros enfoques de identificación de riesgos si han demostrado una utilidad práctica similar y si pueden garantizar los requisitos en 6.1.2 b).

NOTA El enfoque basado en activos, amenazas y vulnerabilidades corresponde al enfoque de identificación de riesgos de seguridad de la información y es compatible con los requisitos de ISO/IEC 27001 para garantizar que no se pierdan las inversiones anteriores en la identificación de riesgos.

No se recomienda que la identificación de riesgos sea demasiado detallada en el primer ciclo de evaluación de riesgos. Tener una imagen de alto nivel pero clara de los riesgos de seguridad de la información es mucho mejor que no tener ninguna imagen.

Orientación sobre el análisis de los riesgos de seguridad de la información (6.1.2 d))

El análisis de riesgo tiene como objetivo determinar el nivel del riesgo.

Se hace referencia a ISO 31000 en ISO/IEC 27001 como un modelo general. ISO/IEC 27001 requiere que para cada riesgo identificado, el análisis de riesgo se base en la evaluación de las consecuencias resultantes del riesgo y la evaluación de la probabilidad de que ocurran esas consecuencias para determinar un nivel de riesgo.

Las técnicas de análisis de riesgo basadas en consecuencias y probabilidad pueden ser:

- 1) cualitativo, utilizando una escala de atributos calificadores (por ejemplo, alto, medio, bajo);
- 2) cuantitativa, utilizando una escala con valores numéricos (por ejemplo, costo monetario, frecuencia o probabilidad de ocurrencia); o
- 3) semicuantitativa, utilizando escalas cualitativas con valores asignados.

Cualquiera que sea la técnica que se utilice para el análisis de riesgos, se debe considerar su nivel de objetividad.

Existen varios métodos para analizar los riesgos. Los dos enfoques mencionados (enfoque basado en eventos y enfoque basado en la identificación de activos, amenazas y vulnerabilidades) pueden ser adecuados para el análisis de riesgos de seguridad de la información. Los procesos de identificación y análisis de riesgos pueden ser más efectivos cuando se llevan a cabo con la ayuda de expertos en los riesgos relevantes en discusión.

Orientación sobre la evaluación de los riesgos de seguridad de la información (6.1.2 e))

La evaluación de los riesgos analizados implica utilizar los procesos de toma de decisiones de la organización para comparar el nivel de riesgo evaluado para cada riesgo con los criterios de aceptación predeterminados para determinar las opciones de tratamiento del riesgo.

Este paso final de la evaluación de riesgos verifica si los riesgos que han sido analizados en los pasos anteriores pueden aceptarse de acuerdo con los criterios de aceptación definidos en 6.1.2 a), o si necesitan un tratamiento adicional. El paso en 6.1.2 d) entrega información sobre la magnitud del riesgo pero no información inmediata sobre la urgencia de implementar opciones de tratamiento del riesgo. Dependiendo de las circunstancias en las que se produzcan los riesgos, pueden tener distintas prioridades de tratamiento. Por lo tanto, el resultado de este paso debe ser una lista de riesgos en orden de prioridad. Es útil retener más información sobre estos riesgos de los pasos de identificación y análisis de riesgos para respaldar las decisiones para el tratamiento de riesgos.

Otra información

ISO/IEC 27005 proporciona orientación para realizar evaluaciones de riesgos de seguridad de la información.

6.1.3 Tratamiento de riesgos de seguridad de la informaciónActividad requerida

La organización define y aplica un proceso de tratamiento de riesgos de seguridad de la información.

Explicación

El tratamiento de riesgos de seguridad de la información es el proceso general de seleccionar opciones de tratamiento de riesgos, determinar los controles apropiados para implementar tales opciones, formular un plan de tratamiento de riesgos y obtener la aprobación del plan de tratamiento de riesgos por parte de los propietarios del riesgo.

Todos los pasos del proceso de tratamiento de riesgos de seguridad de la información (6.1.3 a) a f)), así como los resultados de su aplicación, son retenidos por la organización como información documentada.

GuíaOrientación sobre opciones de tratamiento de riesgos de seguridad de la información (6.1.3 a))

Las opciones de tratamiento del riesgo son:

- a) evitar el riesgo decidiendo no iniciar o continuar con la actividad que genera el riesgo o eliminando la fuente de riesgo (por ejemplo, cerrando un portal de comercio electrónico);
- b) asumir un riesgo adicional o aumentar el riesgo para aprovechar una oportunidad comercial (por ejemplo, abrir un portal de comercio electrónico);
- c) modificar el riesgo cambiando la probabilidad (por ejemplo, reduciendo las vulnerabilidades) o las consecuencias (por ejemplo, diversificación de activos) o ambos;
- d) compartir el riesgo con otras partes mediante seguros, subcontratación o financiación del riesgo; y
- e) retener el riesgo sobre la base de los criterios de aceptación del riesgo o mediante una decisión informada (p. ej., mantener el portal de comercio electrónico existente tal como está).

Cada riesgo individual debe tratarse de acuerdo con los objetivos de seguridad de la información mediante una o más de estas opciones, para cumplir con los criterios de aceptación del riesgo.

Orientación para determinar los controles necesarios (6.1.3 b))

Debe prestarse especial atención a la determinación de los controles de seguridad de la información necesarios.

Cualquier control debe determinarse con base en los riesgos de seguridad de la información previamente evaluados. Si una organización tiene una evaluación de riesgo de seguridad de la información deficiente, tiene una base deficiente para elegir los controles de seguridad de la información.

ISO/IEC 27003:2017(E)

Una determinación de control apropiada asegura:

- f) se incluyen todos los controles necesarios y no se eligen controles innecesarios; y
- g) el diseño de los controles necesarios satisface una amplitud y profundidad adecuadas.

Como consecuencia de una mala elección de controles, el tratamiento del riesgo de seguridad de la información propuesto puede ser:

- h) ineficaz; o
- i) ineficiente y por lo tanto inapropiadamente costoso.

Para garantizar que el tratamiento de los riesgos de seguridad de la información sea eficaz y eficiente, es importante poder demostrar la relación entre los controles necesarios y los resultados de los procesos de evaluación y tratamiento de riesgos.

Puede ser necesario utilizar múltiples controles para lograr el tratamiento requerido del riesgo de seguridad de la información. Por ejemplo, si se elige la opción de cambiar las consecuencias de un evento en particular, puede requerir controles para efectuar la detección rápida del evento, así como controles para responder y recuperarse del evento.

Al determinar los controles, la organización también debería tener en cuenta los controles necesarios para los servicios de proveedores externos de, por ejemplo, aplicaciones, procesos y funciones. Por lo general, estos controles son obligatorios mediante la introducción de requisitos de seguridad de la información en los acuerdos con estos proveedores, incluidas las formas de obtener información sobre hasta qué punto se cumplen estos requisitos (por ejemplo, derecho de auditoría).

Puede haber situaciones en las que la organización desee determinar y describir controles detallados como parte de su propio SGSI aunque los controles sean realizados por proveedores externos. Independientemente del enfoque adoptado, la organización siempre debe considerar los controles necesarios en sus proveedores al determinar los controles para su SGSI.

Orientación sobre la comparación de controles con los de ISO/IEC 27001:2013, Anexo A (6.1.3 c))

ISO/IEC 27001:2013, el Anexo A contiene una lista completa de controles y objetivos de control. Los usuarios de este documento están dirigidos a la representación genérica de los controles en ISO/IEC 27001:2013, Anexo A para garantizar que no se pase por alto ningún control necesario. La comparación con ISO/IEC 27001:2013, Anexo A, también puede identificar controles alternativos a los determinados en 6.1.3 b) que pueden ser más efectivos para modificar el riesgo de seguridad de la información.

Los objetivos de control están implícitamente incluidos en los controles elegidos. Los objetivos de control y los controles enumerados en ISO/IEC 27001:2013, Anexo A, no son exhaustivos y se deben agregar objetivos de control y controles adicionales según sea necesario.

No es necesario incluir todos los controles dentro de ISO/IEC 27001:2013, Anexo A. Se debe excluir cualquier control dentro de ISO/IEC 27001:2013, Anexo A, que no contribuya a modificar el riesgo y se debe dar una justificación para la exclusión.

Orientación sobre la producción de una Declaración de Aplicabilidad (SoA) (6.1.3 d))

El SoA contiene:

- todos los controles necesarios (como se determina en 6.1.3 b) y 6.1.3 c)) y, para cada control:
 - la justificación de la inclusión del control; y
 - si el control está implementado o no (por ejemplo, completamente implementado, en progreso, aún no comenzó); y
- la justificación para excluir cualquiera de los controles en ISO/IEC 27001: 2013, Anexo A.

La justificación para incluir un control en parte se basa en el efecto del control en la modificación de un riesgo de seguridad de la información. Una referencia a los resultados de la evaluación de riesgos de seguridad de la información y el plan de tratamiento de riesgos de seguridad de la información debería ser suficiente, junto con la modificación del riesgo de seguridad de la información esperada por la implementación de los controles necesarios.

La justificación para excluir un control contenido en ISO/IEC 27001:2013, Anexo A, puede incluir lo siguiente:

- se ha determinado que el control no es necesario para implementar la información elegida opciones de tratamiento de riesgos de seguridad;
- el control no es aplicable porque está fuera del alcance del SGSI (p. ej., ISO/IEC 27001:2013, A.14.2.7 El desarrollo subcontratado no es aplicable si todo el desarrollo del sistema de la organización se realiza internamente); y
- se evita mediante un control personalizado (p. ej., en ISO/IEC 27001:2013, A.8.3.1 la gestión de medios extraíbles podría excluirse si un control personalizado impide el uso de medios extraíbles).

NOTA Un control personalizado es un control no incluido en ISO/IEC 27001:2013, Anexo A.

Se puede producir un SoA útil como una tabla que contiene los 114 controles de ISO/IEC 27001:2013, Anexo A a lo largo de las filas más filas con los controles adicionales que no se mencionan en ISO/IEC 27001:2013, Anexo A, si es necesario. Una columna de la tabla puede indicar si un control es necesario para implementar la(s) opción(es) de tratamiento del riesgo o si puede excluirse. Una siguiente columna puede contener la justificación para la inclusión o exclusión de un control. Una última columna de la tabla puede indicar el estado de implementación actual del control. Se pueden utilizar columnas adicionales, como para detalles no requeridos por ISO/IEC 27001 pero generalmente útiles para revisiones posteriores; estos detalles pueden ser una descripción más detallada de cómo se implementa el control o una referencia cruzada a una descripción más detallada e información documentada o políticas relevantes para implementar el control.

Aunque no es un requisito específico de ISO/IEC 27001, las organizaciones pueden encontrar útil incluir responsabilidades para la operación de cada control incluido en el SoA.

Orientación sobre la formulación de un plan de tratamiento de riesgos de seguridad de la información (6.1.3 e))

ISO/IEC 27001 no especifica una estructura o contenido para el plan de tratamiento de riesgos de seguridad de la información. Sin embargo, el plan debe formularse a partir de los resultados de 6.1.3 a) ac). Así, el plan debe documentar para cada riesgo tratado:

- opciones de tratamiento seleccionadas;
- control(es) necesario(s); y
- estado de implementación.

Otro contenido útil puede incluir:

- propietario(s) del riesgo; y
- riesgo residual esperado después de la implementación de las acciones.

Si el plan de tratamiento de riesgos requiere alguna acción, debe planificarse indicando responsabilidades y plazos (ver también 6.2); dicho plan de acción puede representarse mediante una lista de estas acciones.

Se puede diseñar un plan de tratamiento de riesgos de seguridad de la información útil como una tabla ordenada por riesgos identificados durante la evaluación de riesgos, que muestre todos los controles determinados. Como ejemplo, puede haber columnas en esta tabla que indiquen los nombres de las personas responsables de proporcionar los controles. Otras columnas pueden indicar la fecha de implementación del control, información sobre cómo se pretende que funcione el control (o un proceso) y una columna sobre el estado de implementación del objetivo.

Como ejemplo de parte del proceso de tratamiento de riesgos, considere el robo de un teléfono móvil. Las consecuencias son la pérdida de disponibilidad y la posible divulgación no deseada de información. Si la evaluación del riesgo mostró que el nivel de riesgo está fuera de la aceptación, la organización puede decidir cambiar la probabilidad o cambiar las consecuencias del riesgo.

ISO/IEC 27003:2017(E)

Para cambiar la probabilidad de pérdida o robo de un teléfono móvil, la organización puede determinar que un control adecuado es obligar a los empleados a través de una política de dispositivos móviles a cuidar los teléfonos móviles y verificar periódicamente la pérdida.

Para cambiar la consecuencia de la pérdida o robo de un teléfono móvil, la organización puede determinar controles tales como:

- un proceso de gestión de incidentes para que los usuarios puedan reportar la pérdida;
- una solución de gestión de dispositivos móviles (MDM) para eliminar el contenido del teléfono si se pierde; y
- un plan de respaldo de dispositivos móviles para recuperar el contenido del teléfono.

Al preparar su SoA (6.1.3 d)), la organización puede incluir sus controles elegidos (política de dispositivos móviles y MDM), justificando su inclusión en función de su efecto de cambiar la probabilidad y las consecuencias de la pérdida o robo de teléfonos móviles, lo que resulta en una reducción riesgo residual.

Al comparar estos controles con los enumerados en ISO/IEC 27001:2013, Anexo A (6.1.3 c)), se puede ver que la política de dispositivos móviles está alineada con ISO/IEC 27001:2013, A.6.2.1, pero el control MDM no se alinea directamente y debe considerarse como un control personalizado adicional. Si MDM y otros controles se determinan como controles necesarios en el plan de tratamiento de riesgos de seguridad de la información de una organización, deben incluirse en el SoA (consulte "Guía para producir un SoA (6.1.3 d)).

Si la organización quiere reducir aún más el riesgo, puede considerar a partir de ISO/IEC 27001:2013, A.9.1.1 (política de control de acceso) que carecía de control de acceso a teléfonos móviles y modificar su política de dispositivos móviles para exigir el uso de PIN en todos los teléfonos móviles. Este debería ser entonces un control más para cambiar las consecuencias de la pérdida o robo de teléfonos móviles.

Al formular su plan de tratamiento de riesgos de seguridad de la información (6.1.3 e)), la organización debe incluir acciones para implementar la política de dispositivos móviles y MDM y asignar responsabilidades y plazos.

Orientación sobre cómo obtener la aprobación de los propietarios del riesgo (6.1.3 f))

Cuando se formula el plan de tratamiento de riesgos de seguridad de la información, la organización debe obtener la autorización de los propietarios del riesgo. Dicha autorización debe basarse en criterios definidos de aceptación del riesgo o concesión justificada si se desvía de ellos.

A través de sus procesos de gestión, la organización debería registrar la aceptación del riesgo residual por parte del propietario del riesgo y la aprobación del plan por parte de la dirección.

Como ejemplo, la aprobación de este propietario del riesgo se puede documentar modificando el plan de tratamiento del riesgo descrito en la orientación de 6.1.3 e) mediante columnas que indiquen la eficacia del control, el riesgo residual y la aprobación del propietario del riesgo.

Otra información

Se puede encontrar más información sobre el tratamiento de riesgos en ISO/IEC 27005 e ISO 31000.

6.2 Objetivos de seguridad de la información y planificación para alcanzarlos

Actividad requerida

La organización establece objetivos de seguridad de la información y planes para lograrlos en las funciones y niveles relevantes.

Explicación

Los objetivos de seguridad de la información ayudan a implementar las metas estratégicas de una organización, así como a implementar la política de seguridad de la información. Por lo tanto, los objetivos de un SGSI son los objetivos de seguridad de la información para la confidencialidad, integridad y disponibilidad de la información. Los objetivos de seguridad de la información también ayudan a especificar y medir el desempeño de los controles y procesos de seguridad de la información, de acuerdo con la política de seguridad de la información (ver 5.2).

La organización planifica, establece y emite objetivos de seguridad de la información para las funciones relevantes y niveles

Los requisitos de ISO/IEC 27001 relativos a los objetivos de seguridad de la información se aplican a todos los objetivos de seguridad de la información. Si la política de seguridad de la información contiene objetivos, entonces se requiere que esos objetivos cumplan con los criterios en 6.2. Si la política contiene un marco para establecer objetivos, entonces se requiere que los objetivos producidos por ese marco cumplan con los requisitos de 6.2.

Los requisitos a tener en cuenta al establecer los objetivos son aquellos determinados al comprender la organización y su contexto (ver 4.1), así como las necesidades y expectativas de las partes interesadas (ver 4.2).

Los resultados de las evaluaciones de riesgos y los tratamientos de riesgos se utilizan como entrada para la revisión continua de los objetivos para garantizar que sigan siendo apropiados para las circunstancias de una organización.

Los objetivos de seguridad de la información son entradas para la evaluación de riesgos: los criterios de aceptación de riesgos y los criterios para realizar evaluaciones de riesgos de seguridad de la información (consulte 6.1.2) tienen en cuenta estos objetivos de seguridad de la información y, por lo tanto, garantizan que los niveles de riesgo estén alineados con ellos.

Los objetivos de seguridad de la información según ISO/IEC 27001 son:

- a) consistente con la política de seguridad de la información;
- b) medible si es practicable; esto significa que es importante poder determinar si un se ha cumplido el objetivo;
- c) conectado a los requisitos de seguridad de la información aplicables, y los resultados de la evaluación de riesgos y tratamiento de riesgos;
- d) comunicado; y
- e) actualizado según corresponda.

La organización conserva información documentada sobre los objetivos de seguridad de la información.

Al planificar cómo lograr sus objetivos de seguridad de la información, la organización determina:

- f) lo que se hará;
- g) qué recursos se requerirán;
- h) quién será responsable;
- i) cuándo se completará; y
- j) cómo se evaluarán los resultados.

El requisito anterior relativo a la planificación es genérico y aplicable a otros planes requeridos por ISO/IEC 27001. Los planes a considerar para un SGSI incluyen:

- planes para mejorar el SGSI como se describe en 6.1.1 y 8.1;
- planes para tratar los riesgos identificados como se describe en 6.1.3 y 8.3; y

ISO/IEC 27003:2017(E)

— cualquier otro plan que se considere necesario para una operación eficaz (por ejemplo, planes para desarrollar competencias y aumentar la conciencia, comunicación, evaluación del desempeño, auditorías internas y revisiones de la dirección).

Guía

La política de seguridad de la información debe establecer los objetivos de seguridad de la información o proporcionar un marco para establecer los objetivos.

Los objetivos de seguridad de la información se pueden expresar de varias maneras. La expresión debe ser adecuada para cumplir con el requisito de ser medible (si es factible) (ISO/IEC 27001:2013, 6.2 b)).

Por ejemplo, los objetivos de seguridad de la información se pueden expresar en términos de:

- valores numéricos con sus límites, por ejemplo, “no sobrepasar cierto límite” y “alcanzar el nivel 4”;
- los objetivos para las mediciones del desempeño de la seguridad de la información;
- los objetivos para las mediciones de la efectividad del SGSI (ver 9.1);
- conformidad con ISO/IEC 27001;
- cumplimiento de los procedimientos del SGSI;
- la necesidad de completar acciones y planes; y
- criterios de riesgo que deben cumplirse.

La siguiente guía se aplica a las viñetas abordadas en la explicación:

- ver a) arriba. La política de seguridad de la información especifica los requisitos para la seguridad de la información en una organización. Todos los demás requisitos específicos establecidos para funciones y niveles relevantes deben ser consistentes con ellos. Si la política de seguridad de la información tiene objetivos de seguridad de la información, cualquier otro objetivo específico de seguridad de la información debe estar vinculado a los de la política de seguridad de la información. Si la política de seguridad de la información solo proporciona el marco para establecer objetivos, entonces se debe seguir ese marco y garantizar que los objetivos más específicos estén vinculados a los más genéricos;
- ver b) arriba. No todos los objetivos pueden ser medibles, pero hacer que los objetivos sean medibles respalda el logro y la mejora. Es muy deseable poder describir, cualitativa o cuantitativamente, el grado en que se ha cumplido un objetivo. Por ejemplo, para orientar las prioridades para un esfuerzo adicional si no se cumplen los objetivos, o para proporcionar información sobre las oportunidades para mejorar la eficacia si se superan los objetivos. Debería ser posible comprender si se han logrado o no, cómo se determina el logro de los objetivos y si es posible determinar el grado de logro de los objetivos utilizando mediciones cuantitativas. Las descripciones cuantitativas del logro de objetivos deben especificar cómo se realiza la medición asociada. Puede que no sea posible determinar cuantitativamente el grado de consecución de todos los objetivos. ISO/IEC 27001 requiere que los objetivos sean medibles si es factible;
- ver c) arriba. Los objetivos de seguridad de la información deben estar alineados con las necesidades de seguridad de la información; por esta razón, los resultados de la evaluación y el tratamiento de riesgos deben utilizarse como insumos al establecer los objetivos de seguridad de la información;
- ver d) arriba. Los objetivos de seguridad de la información deben comunicarse a las partes interesadas internas relevantes de la organización. También se pueden comunicar a partes interesadas externas, por ejemplo, clientes, partes interesadas, en la medida en que necesiten saber y se vean afectados por los objetivos de seguridad de la información; y
- ver e) arriba. Cuando las necesidades de seguridad de la información cambien con el tiempo, los objetivos de seguridad de la información relacionados deben actualizarse en consecuencia. Su actualización deberá ser comunicada como se requiere en d), a las partes interesadas internas y externas según corresponda.

La organización debe planificar cómo lograr sus objetivos de seguridad de la información. La organización puede utilizar cualquier metodología o mecanismo que elija para planificar el logro de sus objetivos de seguridad de la información. Puede haber un solo plan de seguridad de la información, uno o más planes de proyecto, o acciones incluidas en otros planes organizacionales. Cualquiera que sea la forma que tome la planificación, los planes resultantes deben definir como mínimo (ver f) a j) arriba):

- las actividades a realizar;
- los recursos necesarios que se comprometerán para ejecutar las actividades;
- las responsabilidades;
- los plazos y los hitos de las actividades; y
- los métodos y mediciones para evaluar si los resultados alcanzan los objetivos, lo que incluye el calendario de dichas evaluaciones.

ISO/IEC 27001 requiere que las organizaciones conserven información documentada sobre los objetivos de seguridad de la información. Dicha información documentada puede incluir:

- planes, acciones, recursos, responsabilidades, plazos y métodos de evaluación; y
- requisitos, tareas, recursos, responsabilidades, frecuencia y métodos de evaluación.

Otra información

Ninguna otra información.

7 Soporte

7.1 Recursos

Actividad requerida

La organización determina y proporciona los recursos para establecer, implementar, mantener y mejorar continuamente el SGSI.

Explicación

Los recursos son fundamentales para realizar cualquier tipo de actividad. Las categorías de recursos pueden incluir:

- a) personas para conducir y operar las actividades;
- b) tiempo para realizar actividades y tiempo para permitir que los resultados se asienten antes de dar un nuevo paso;
- c) recursos financieros para adquirir, desarrollar e implementar lo que se necesita;
- d) información para apoyar decisiones, medir el desempeño de acciones y mejorar el conocimiento; y
- e) infraestructura y otros medios que puedan ser adquiridos o contruidos, tales como tecnología, herramientas y materiales, sean o no productos de tecnología de la información.

Estos recursos deben mantenerse alineados con las necesidades del SGSI y, por lo tanto, deben adaptarse cuando sea necesario.

Guía

La organización debería:

- f) estimar los recursos necesarios para todas las actividades relacionadas con el SGSI en términos de cantidad y calidad (capacidades y capacidades);
- g) adquirir los recursos necesarios;

ISO/IEC 27003:2017(E)

h) proporcionar los recursos;

i) mantener los recursos en todos los procesos del SGSI y actividades específicas; y

j) revisar los recursos proporcionados frente a las necesidades del SGSI y ajustarlos según sea necesario.

La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).

Otra información

Ninguna otra información.

7.2 Competencia

Actividad requerida

La organización determina la competencia de las personas necesarias para el desempeño de la seguridad de la información y asegura que las personas sean competentes.

Explicación

La competencia es la capacidad de aplicar conocimientos y habilidades para lograr los resultados previstos. Está influenciado por el conocimiento, la experiencia y la sabiduría.

La competencia puede ser específica (p. ej., sobre tecnología o áreas de gestión específicas, como la gestión de riesgos) o general (p. ej., habilidades blandas, confiabilidad y temas tecnológicos y de gestión básicos).

La competencia se refiere a las personas que trabajan bajo el control de la organización. Esto significa que la competencia debe administrarse para las personas que son empleados de la organización y para otras personas según sea necesario.

La adquisición de competencias y habilidades superiores o nuevas puede lograrse tanto interna como externamente a través de la experiencia, la formación (p. ej., cursos, seminarios y talleres), la tutoría, la contratación o la contratación de personas externas.

Para la competencia que solo se necesita temporalmente, para una actividad específica o por un período corto de tiempo, por ejemplo, para cubrir una escasez temporal inesperada de personal interno, las organizaciones pueden contratar o contratar recursos externos, cuya competencia debe describirse y verificarse.

Guía

La organización debería:

a) determinar la competencia esperada para cada rol dentro del SGSI y decidir si es necesario documentado (por ejemplo, en una descripción del trabajo);

b) asignar los roles dentro del SGSI (ver 5.3) a personas con la competencia requerida ya sea por:

- 1) identificar a las personas dentro de la organización que tienen la competencia (basándose, por ejemplo, en su educación, experiencia o certificaciones);
- 2) planificar e implementar acciones para que las personas dentro de la organización obtengan la competencia (por ejemplo, mediante la provisión de capacitación, tutoría, reasignación de empleados actuales); o
- 3) involucrar a nuevas personas que tengan la competencia (por ejemplo, mediante contratación o contratación);

c) evaluar la efectividad de las acciones en b) anterior;

EJEMPLO 1

Considere si las personas han adquirido competencia después de la capacitación.

EJEMPLO 2 Analizar la competencia de las personas recién contratadas o contratadas un tiempo después de su llegada a la organización.

EJEMPLO 3 Verificar si el plan de captación de nuevas personas se ha completado como se esperaba.

d) verificar que las personas sean competentes para sus funciones; y

e) asegurar que la competencia evolucione con el tiempo según sea necesario y que cumpla con las expectativas.

Se requiere información documentada apropiada como evidencia de competencia. Por lo tanto, la organización debe conservar la documentación sobre la competencia necesaria que afecta el desempeño de la seguridad de la información y cómo las personas relevantes cumplen esta competencia.

Otra información

Ninguna otra información.

7.3 Conciencia

Actividad requerida

Las personas que realizan el trabajo bajo el control de la organización conocen la política de seguridad de la información, su contribución a la eficacia del SGSI, los beneficios de mejorar el desempeño de la seguridad de la información y las implicaciones de no cumplir con los requisitos del SGSI.

Explicación

La conciencia de las personas que trabajan bajo el control de la organización se refiere a tener la comprensión y motivación necesarias sobre lo que se espera de ellos con respecto a la seguridad de la información.

La conciencia concierne a las personas que tienen que saber, comprender, aceptar y:

a) apoyar los objetivos establecidos en la política de seguridad de la información; y

b) seguir las reglas para realizar correctamente sus tareas diarias en apoyo de la seguridad de la información.

Además, las personas que realizan el trabajo bajo el control de la organización también deben conocer, comprender y aceptar las implicaciones de no cumplir con los requisitos del SGSI. Las implicaciones pueden ser consecuencias negativas para la seguridad de la información o repercusiones para la persona.

Estas personas deben saber que existe una política de seguridad de la información y dónde encontrar información al respecto. Muchos miembros del personal de una organización no necesitan conocer el contenido detallado de la política. En su lugar, deben conocer, comprender, aceptar e implementar los objetivos y requisitos de seguridad de la información derivados de la política que afectan a su puesto de trabajo. Estos requisitos pueden incluirse en los estándares o procedimientos que se espera que sigan para hacer su trabajo.

Guía

La organización debería:

c) preparar un programa con los mensajes específicos enfocados en cada audiencia (por ejemplo, interna y personas externas);

d) incluir las necesidades y expectativas de seguridad de la información dentro de los materiales de concientización y capacitación sobre otros temas para ubicar las necesidades de seguridad de la información en contextos operativos relevantes;

e) preparar un plan para comunicar mensajes a intervalos planificados;

f) verificar el conocimiento y la comprensión de los mensajes tanto al final de una sesión de sensibilización como al azar entre sesiones; y

g) verificar si las personas actúan de acuerdo con los mensajes comunicados y usar ejemplos de comportamiento 'bueno' y 'malo' para reforzar el mensaje.

ISO/IEC 27003:2017(E)

La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).

Otra información

Se puede encontrar más información sobre la concienciación en el campo de la seguridad de la información en ISO/IEC 27002:2013, 7.2.2.

7.4 Comunicación

Actividad requerida

La organización determina las necesidades de comunicaciones internas y externas relacionadas con el SGSI.

Explicación

La comunicación es un proceso clave dentro de un SGSI. Es necesaria una comunicación adecuada con las partes interesadas internas y externas (ver 4.2).

La comunicación puede ser entre partes interesadas internas en todos los niveles de la organización o entre la organización y partes interesadas externas. La comunicación puede iniciarse dentro de la organización o por una parte interesada externa.

Las organizaciones necesitan determinar:

- qué contenido debe comunicarse, por ejemplo, políticas de seguridad de la información, objetivos, procedimientos, sus cambios, conocimiento sobre los riesgos de seguridad de la información, requisitos para los proveedores y retroalimentación sobre el desempeño de la seguridad de la información;
- el momento preferido u óptimo para las actividades de comunicación;
- quién participará en las actividades de comunicación y cuál es el público objetivo de cada esfuerzo de comunicación;
- quién debe iniciar las actividades de comunicación, por ejemplo, un contenido específico puede requerir que la comunicación sea iniciado por una persona u organización específica; y
- qué procesos están impulsando o iniciando actividades de comunicación, y qué procesos están objetivo o afectado por las actividades de comunicación.

La comunicación puede tener lugar regularmente o según surjan las necesidades. Puede ser proactiva o reactiva.

Guía

La comunicación se basa en procesos, canales y protocolos. Estos deben elegirse para garantizar que el mensaje comunicado se reciba íntegramente, se comprenda correctamente y, cuando sea pertinente, se actúe en consecuencia.

Las organizaciones deben determinar qué contenido debe comunicarse, por ejemplo:

- a) planes y resultados de la gestión de riesgos a las partes interesadas según sea necesario y apropiado, en la identificación, análisis, evaluación y tratamiento de los riesgos;
- b) objetivos de seguridad de la información;
- c) logros objetivos de seguridad de la información, incluidos aquellos que pueden respaldar su posición en el mercado (p. ej., certificado ISO/IEC 27001 otorgado; declaración de conformidad con las leyes de protección de datos personales);
- d) incidentes o crisis, donde la transparencia suele ser clave para preservar y aumentar la confianza en la capacidad de la organización para gestionar la seguridad de la información y hacer frente a situaciones inesperadas;

- e) roles, responsabilidades y autoridad;
- f) información intercambiada entre funciones y roles según lo requieran los procesos del SGSI;
- g) cambios al SGSI;
- h) otros asuntos identificados mediante la revisión de los controles y procesos dentro del alcance del SGSI;
- i) asuntos (por ejemplo, notificación de incidentes o crisis) que requieren comunicación a los organismos reguladores u otras partes interesadas; y
- j) solicitudes u otras comunicaciones de partes externas como clientes, clientes potenciales, usuarios de servicios y autoridades.

La organización debería identificar los requisitos para la comunicación sobre temas relevantes:

- k) a quién se le permite comunicarse externa e internamente (p. ej., en casos especiales, como una violación de datos), asignándose roles específicos con la autoridad correspondiente. Por ejemplo, los oficiales de comunicación oficial se pueden definir con la autoridad correspondiente. Podrían ser un oficial de relaciones públicas para la comunicación externa y un oficial de seguridad para la comunicación interna;
- l) los desencadenantes o la frecuencia de la comunicación (por ejemplo, para la comunicación de un evento, el desencadenante es la identificación del evento);
- m) el contenido de los mensajes para las partes interesadas clave (p. ej., clientes, reguladores, público en general, usuarios internos importantes) sobre la base de escenarios de impacto de alto nivel. La comunicación puede ser más eficaz si se basa en mensajes preparados y aprobados previamente por un nivel de gestión adecuado como parte de un plan de comunicación, el plan de respuesta a incidentes o el plan de continuidad del negocio;
- n) los destinatarios previstos de la comunicación; en algunos casos, se debe mantener una lista (por ejemplo, para comunicar cambios en los servicios o crisis);
- o) los medios y canales de comunicación. La comunicación debe utilizar medios y canales dedicados, para asegurarse de que el mensaje sea oficial y tenga la autoridad adecuada. Los canales de comunicación deben abordar cualquier necesidad de protección de la confidencialidad e integridad de la información transmitida; y
- p) el proceso diseñado y el método para asegurar que los mensajes se envían y han sido recibidos correctamente y entendido.

La comunicación debe clasificarse y manejarse de acuerdo con los requisitos de la organización.

La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).

Otra información

Ninguna otra información.

7.5 Información documentada

7.5.1 Generalidades

Actividad requerida

La organización incluye información documentada en el SGSI según lo exige directamente la norma ISO/IEC 27001, así como la que la organización determina como necesaria para la eficacia del SGSI.

ISO/IEC 27003:2017(E)

Explicación

La información documentada es necesaria para definir y comunicar los objetivos, la política, las directrices, las instrucciones, los controles, los procesos, los procedimientos de seguridad de la información y lo que se espera que hagan las personas o grupos de personas y cómo se espera que se comporten. También se necesita información documentada para las auditorías del SGSI y para mantener un SGSI estable cuando cambian las personas en funciones clave. Además, se necesita información documentada para registrar acciones, decisiones y resultados de los procesos del SGSI y los controles de seguridad de la información.

La información documentada puede contener:

- información sobre objetivos, riesgos, requisitos y estándares de seguridad de la información;
- información sobre los procesos y procedimientos a seguir; y
- registros de las entradas (p. ej., para revisiones por la dirección) y los resultados de los procesos (incluidos los planes y los resultados de las actividades operativas).

Hay muchas actividades dentro del SGSI que producen información documentada que se utiliza, la mayor parte del tiempo, como entrada para otra actividad.

ISO/IEC 27001 requiere un conjunto de información documentada obligatoria y contiene un requisito general de que se requiere información documentada adicional si es necesaria para la efectividad del SGSI.

La cantidad de información documentada necesaria a menudo está relacionada con el tamaño de la organización.

En total, la información documentada obligatoria y adicional contiene información suficiente para permitir que se lleven a cabo los requisitos de evaluación del desempeño especificados en [la Cláusula 9](#).

Guía

La organización debe determinar qué información documentada es necesaria para garantizar la eficacia de su SGSI además de la información documentada obligatoria requerida por ISO/IEC 27001.

La información documentada debe estar allí para cumplir con el propósito. Lo que se necesita es información fáctica y 'al grano'.

Ejemplos de información documentada que la organización puede determinar que es necesaria para garantizar la eficacia de su SGSI son:

- los resultados del establecimiento del contexto (ver [Cláusula 4](#)); _____
- los roles, responsabilidades y autoridades (ver [la Cláusula 5](#)); _____
- informes de las diferentes fases de la gestión de riesgos (ver [Cláusula 6](#)); _____
- recursos determinados y provistos (ver [7.1](#)); _____
- la competencia esperada (ver [7.2](#)); _____
- planes y resultados de las actividades de sensibilización (véase [7.3](#)); _____
- planes y resultados de las actividades de comunicación (ver [7.4](#)); _____
- información documentada de origen externo que sea necesaria para el SGSI (ver [7.5.3](#)); _____
- proceso para controlar la información documentada (ver [7.5.3](#)); _____
- políticas, reglas y directivas para dirigir y operar actividades de seguridad de la información;
- procesos y procedimientos utilizados para implementar, mantener y mejorar el SGSI y el estado general de seguridad de la información (ver [la Cláusula 9](#)); _____
- plan de acción; y

— evidencia de los resultados de los procesos del SGSI (por ejemplo, gestión de incidentes, control de acceso, información continuidad de seguridad, mantenimiento de equipos, etc.).

La información documentada puede ser de origen interno o externo.

Otra información

Si la organización desea gestionar su información documentada en un sistema de gestión de documentos, este se puede construir de acuerdo con los requisitos de la norma ISO 30301.

7.5.2 Creación y actualización

Actividad requerida

Al crear y actualizar información documentada, la organización asegura su adecuada identificación y descripción, formato y medios, y revisión y aprobación.

Explicación

La organización identifica en detalle cómo se estructura mejor la información documentada y define un enfoque de documentación adecuado.

La revisión y aprobación por parte de la gerencia adecuada asegura que la información documentada sea correcta, adecuada para el propósito y en una forma y detalle adecuados para la audiencia prevista. Las revisiones periódicas aseguran la idoneidad y adecuación continuas de la información documentada.

Guía

La información documentada se puede conservar en cualquier forma, por ejemplo, documentos tradicionales (tanto en papel como en formato electrónico), páginas web, bases de datos, registros de computadora, informes generados por computadora, audio y video. Además, la información documentada puede consistir en especificaciones de intención (p. ej., la política de seguridad de la información) o registros de desempeño (p. ej., los resultados de una auditoría) o una combinación de ambos. La siguiente guía se aplica directamente a los documentos tradicionales y debe interpretarse adecuadamente cuando se aplica a otras formas de información documentada.

Las organizaciones deben crear una biblioteca de información documentada estructurada, vinculando diferentes partes de la información documentada mediante:

- a) determinar la estructura del marco de información documentada;
- b) determinar la estructura estándar de la información documentada;
- c) proporcionar plantillas para diferentes tipos de información documentada;
- d) determinar las responsabilidades para la elaboración, aprobación, publicación y gestión de la información documentada;
y
- e) determinar y documentar el proceso de revisión y aprobación para garantizar la idoneidad continua
y adecuación.

Las organizaciones deben definir un enfoque de documentación que incluya atributos comunes de cada documento, que permitan una identificación clara y única. Estos atributos suelen incluir el tipo de documento (p. ej., política, directiva, regla, directriz, plan, formulario, proceso o procedimiento), el propósito y el alcance, el título, la fecha de publicación, la clasificación, el número de referencia, el número de versión y un historial de revisión. Se debe incluir la identificación del autor y de la(s) persona(s) actualmente responsable(s) del documento, su aplicación y evolución, así como del(los) aprobador(es) o autoridad de aprobación.

Los requisitos de formato pueden incluir la definición de idiomas de documentación adecuados, formatos de archivo, versión de software para trabajar con ellos y contenido gráfico. Los requisitos de los medios definen en qué medios físicos y electrónicos debe estar disponible la información.

Las declaraciones y el estilo de escritura deben adaptarse a la audiencia y el alcance de la documentación.

ISO/IEC 27003:2017(E)

Debe evitarse la duplicación de información en la información documentada y deben utilizarse referencias cruzadas en lugar de replicar la misma información en diferentes documentos.

El enfoque de documentación debe garantizar la revisión oportuna de la información documentada y que todos los cambios en la documentación estén sujetos a aprobación. Los criterios de revisión adecuados pueden estar relacionados con el tiempo (por ejemplo, períodos máximos de tiempo entre revisiones de documentos) o relacionados con el contenido. Deben definirse criterios de aprobación que aseguren que la información documentada sea correcta, adecuada para el propósito y en una forma y detalle adecuados para la audiencia prevista.

Otra información

Ninguna otra información.

7.5.3 Control de la información documentada

Actividad requerida

La organización gestiona la información documentada a lo largo de su ciclo de vida y la pone a disposición donde y cuando sea necesario.

Explicación

Una vez aprobada, la información documentada se comunica a su audiencia prevista. La información documentada está disponible donde y cuando se necesita, preservando su integridad, confidencialidad y relevancia a lo largo de todo el ciclo de vida.

Tenga en cuenta que las actividades descritas "según corresponda" en ISO/IEC 27001:2013, 7.5.3 deben realizarse si se pueden realizar y son útiles, teniendo en cuenta las necesidades y expectativas de la organización.

Guía

Se puede utilizar una biblioteca de información documentada estructurada para facilitar el acceso a la información documentada.

Toda la información documentada debe clasificarse (ver ISO/IEC 27001:2013, A.8.2.1) de acuerdo con el esquema de clasificación de la organización. La información documentada debe protegerse y manejarse de acuerdo con su nivel de clasificación (ver ISO/IEC 27001:2013, A.8.2.3).

Un proceso de gestión de cambios para la información documentada debe garantizar que solo las personas autorizadas tengan derecho a cambiarla y distribuirla según sea necesario a través de medios apropiados y predefinidos. La información documentada debe protegerse para garantizar que mantenga su validez y autenticidad.

La información documentada debe distribuirse y ponerse a disposición de las partes interesadas autorizadas. Para esto, la organización debe establecer quiénes son las partes interesadas relevantes para cada información documentada (o grupos de información documentada), y los medios a utilizar para su distribución, acceso, recuperación y uso (por ejemplo, un sitio web con mecanismos de control de acceso apropiados). La distribución debe cumplir con los requisitos relacionados con la protección y el manejo de información clasificada.

La organización debería establecer el período de retención apropiado para la información documentada de acuerdo con su validez prevista y otros requisitos relevantes. La organización debe asegurarse de que la información sea legible durante todo su período de retención (por ejemplo, utilizando formatos que puedan leerse con el software disponible o verificando que el papel no esté dañado).

La organización debe establecer qué hacer con la información documentada después de que haya expirado su período de retención.

La organización también debería gestionar información documentada de origen externo (es decir, de clientes, socios, proveedores, organismos reguladores, etc.).

La información documentada sobre esta actividad y su resultado es obligatoria solo en la forma y en la medida en que la organización lo determine como necesario para la eficacia de su sistema de gestión (ver ISO/IEC 27001:2013, 7.5.1 b)).

Otra información

Ninguna otra información.

8 Operación

8.1 Planificación y control operativo

Actividad requerida

La organización planifica, implementa y controla los procesos para cumplir con sus requisitos de seguridad de la información y lograr sus objetivos de seguridad de la información.

La organización mantiene la información documentada necesaria para tener la confianza de que los procesos se llevan a cabo según lo planeado.

La organización controla los cambios planificados y revisa las consecuencias de los cambios no deseados, y asegura que los procesos subcontratados se identifiquen, definan y controlen.

Explicación

Los procesos que utiliza una organización para cumplir con sus requisitos de seguridad de la información se planifican y, una vez implementados, se controlan, en particular cuando se requieren cambios.

Sobre la base de la planificación del SGSI (ver 6.1 y 6.2), la organización realiza la planificación y las actividades operativas necesarias para implementar los procesos necesarios para cumplir con los requisitos de seguridad de la información.

Los procesos para cumplir con los requisitos de seguridad de la información incluyen:

- a) Procesos del SGSI (p. ej., revisión por la dirección, auditoría interna); y
- b) los procesos necesarios para implementar el plan de tratamiento de riesgos de seguridad de la información.

La implementación de los planes resulta en procesos operados y controlados.

En última instancia, la organización sigue siendo responsable de la planificación y el control de los procesos subcontratados para lograr sus objetivos de seguridad de la información. Por lo tanto, la organización necesita:

- c) determinar los procesos subcontratados considerando los riesgos de seguridad de la información relacionados con la subcontratación; y
- d) garantizar que los procesos subcontratados se controlen (es decir, se planifiquen, supervisen y revisen) de manera que proporcionen seguridad de que funcionan según lo previsto (considerando también los objetivos de seguridad de la información y el plan de tratamiento de riesgos de seguridad de la información).

Una vez que se completa la implementación, los procesos se gestionan, monitorean y revisan para garantizar que continúen cumpliendo con los requisitos determinados luego de comprender las necesidades y expectativas de las partes interesadas (ver 4.2).

Los cambios del SGSI en funcionamiento pueden planificarse o pueden ocurrir de forma no intencionada. Cada vez que la organización realiza cambios en el SGSI (como resultado de la planificación o sin intención), evalúa las posibles consecuencias de los cambios para controlar cualquier efecto adverso.

La organización puede tener confianza en la efectividad de la implementación de los planes al documentar actividades y usar información documentada como entrada para los procesos de evaluación del desempeño especificados en la Cláusula 9. Por lo tanto, la organización establece la información documentada requerida para mantener.

ISO/IEC 27003:2017(E)

Guía

Los procesos que se han definido como resultado de la planificación descrita en [la Cláusula 6](#) deben implementarse, operarse y verificarse en toda la organización. Se debe considerar e implementar lo siguiente:

- e) procesos que son específicos para la gestión de la seguridad de la información (tales como gestión de riesgos, gestión de incidentes, gestión de continuidad, auditorías internas, revisiones de gestión);
- f) procesos que emanan de los controles de seguridad de la información en el riesgo de seguridad de la información plan de tratamiento;
- g) estructuras de reporte (contenido, frecuencia, formato, responsabilidades, etc.) dentro del área de seguridad de la información, por ejemplo reportes de incidentes, reportes de medición del cumplimiento de objetivos de seguridad de la información, reportes de actividades realizadas; y
- h) estructuras de reuniones (frecuencia, participantes, objeto y autorización) dentro del área de seguridad de la información. Las actividades de seguridad de la información deben ser coordinadas por representantes de diferentes partes de la organización con roles y funciones laborales relevantes para la gestión eficaz del área de seguridad de la información.

Para los cambios planificados, la organización debería:

- i) planificar su implementación y asignar tareas, responsabilidades, plazos y recursos;
- j) implementar cambios de acuerdo al plan;
- k) monitorear su implementación para confirmar que se implementen de acuerdo con el plan; y
- l) recopilar y conservar información documentada sobre la ejecución de los cambios como evidencia de que se han llevado a cabo según lo planeado (por ejemplo, con responsabilidades, plazos, evaluaciones de efectividad).

Para los cambios no deseados observados, la organización debería:

- m) revisar sus consecuencias;
- n) determinar si ya se han producido o pueden producirse efectos adversos en el futuro;
- o) planificar e implementar acciones para mitigar cualquier efecto adverso según sea necesario; y
- p) recopilar y conservar información documentada sobre cambios no deseados y acciones tomadas para mitigar efectos adversos.

Si parte de las funciones o procesos de la organización se subcontratan a proveedores, la organización debería:

- q) determinar todas las relaciones de subcontratación;
- r) establecer interfaces apropiadas con los proveedores;
- s) abordar cuestiones relacionadas con la seguridad de la información en los acuerdos con los proveedores;
- t) monitorear y revisar los servicios del proveedor para garantizar que se operen según lo previsto y que los riesgos de seguridad de la información asociados cumplan con los criterios de aceptación de riesgos de la organización; y
- u) gestionar cambios en los servicios del proveedor según sea necesario.

Otra información

Ninguna otra información.

8.2 Evaluación de riesgos de seguridad de la información

Actividad requerida

La organización realiza evaluaciones de riesgos de seguridad de la información y retiene información documentada sobre sus resultados.

Explicación

Al realizar evaluaciones de riesgos de seguridad de la información, la organización ejecuta el proceso definido en [6.1.2](#). Estas evaluaciones se ejecutan de acuerdo con un cronograma definido de antemano o en respuesta a cambios significativos o incidentes de seguridad de la información. Los resultados de las evaluaciones de riesgos de seguridad de la información se conservan en la información documentada como evidencia de que el proceso en [6.1.2](#) se ha realizado según lo definido.

La información documentada de las evaluaciones de riesgos de seguridad de la información es esencial para el tratamiento de riesgos de seguridad de la información y es valiosa para la evaluación del desempeño (consulte [la Cláusula 9](#)).

Guía

Las organizaciones deben tener un plan para realizar evaluaciones de riesgos de seguridad de la información programadas.

Cuando se han producido cambios significativos en el SGSI (o su contexto) o incidentes de seguridad de la información, la organización debe determinar:

- a) cuáles de estos cambios o incidentes requieren una evaluación adicional de riesgos de seguridad de la información; y
- b) cómo se desencadenan estas evaluaciones.

El nivel de detalle de la identificación de riesgos debe refinarse paso a paso en futuras iteraciones de la evaluación de riesgos de seguridad de la información en el contexto de la mejora continua del SGSI. Se debe realizar una evaluación amplia de riesgos de seguridad de la información al menos una vez al año.

Otra información

ISO/IEC 27005 proporciona orientación para realizar evaluaciones de riesgos de seguridad de la información.

8.3 Tratamiento de riesgos de seguridad de la información

Actividad requerida

La organización implementa el plan de tratamiento de riesgos de seguridad de la información y conserva información documentada sobre los resultados del tratamiento de seguridad de la información.

Explicación

Para tratar los riesgos de seguridad de la información, la organización necesita llevar a cabo el proceso de tratamiento de riesgos de seguridad de la información definido en [6.1.3](#). Durante la operación del SGSI, cada vez que se actualiza la evaluación de riesgos de acuerdo con [8.2](#), la organización aplica el tratamiento de riesgos de acuerdo con [6.1.3](#) y actualiza el plan de tratamiento de riesgos. Se implementa nuevamente el plan de tratamiento de riesgos actualizado.

Los resultados del tratamiento del riesgo de seguridad de la información se conservan en la información documentada como evidencia de que el proceso en [6.1.3](#) se ha realizado según lo definido.

Guía

El proceso de tratamiento de riesgos de seguridad de la información debe realizarse después de cada iteración del proceso de evaluación de seguridad de la información en [8.2](#) o cuando falla la implementación del plan de tratamiento de riesgos o partes del mismo.

El progreso de la implementación del plan de tratamiento de riesgos de seguridad de la información debe ser impulsado y monitoreado por esta actividad.

ISO/IEC 27003:2017(E)

Otra información

Ninguna otra información.

9 Evaluación del desempeño

9.1 Seguimiento, medición, análisis y evaluación

Actividad requerida

La organización evalúa el desempeño de la seguridad de la información y la efectividad del SGSI.

Explicación

El objetivo del monitoreo y la medición es ayudar a la organización a juzgar si el resultado previsto de las actividades de seguridad de la información, incluida la evaluación y el tratamiento de riesgos, se logra según lo planeado.

El seguimiento determina el estado de un sistema, un proceso o una actividad, mientras que la medición es un proceso para determinar un valor. Por lo tanto, el seguimiento se puede lograr a través de una sucesión de mediciones similares durante un período de tiempo.

Para el seguimiento y la medición, la organización establece:

- a) qué monitorear y medir;
- b) quién monitorea y mide, y cuándo; y
- c) métodos a utilizar para producir resultados válidos (es decir, comparables y reproducibles).

Para el análisis y evaluación, la organización establece:

- d) quién analiza y evalúa los resultados del seguimiento y la medición, y cuándo; y
- e) métodos a utilizar para producir resultados válidos.

Hay dos aspectos de la evaluación:

- f) evaluar el desempeño de la seguridad de la información, para determinar si la organización está funcionando como se esperaba, lo que incluye determinar qué tan bien los procesos dentro del SGSI cumplen con sus especificaciones; y
- g) evaluar la efectividad del SGSI, para determinar si la organización está haciendo lo correcto o no, lo que incluye determinar hasta qué punto se logran los objetivos de seguridad de la información.

Tenga en cuenta que "según corresponda" (ISO/IEC 27001:2013, 9.1, b)) significa que si se pueden determinar los métodos de seguimiento, medición, análisis y evaluación, es necesario determinarlos.

Guía

Una buena práctica es definir la 'necesidad de información' al planificar el seguimiento, la medición, el análisis y la evaluación. Una necesidad de información generalmente se expresa como una pregunta o declaración de seguridad de la información de alto nivel que ayuda a la organización a evaluar el desempeño de la seguridad de la información y la efectividad del SGSI. En otras palabras, el seguimiento y la medición deben llevarse a cabo para lograr un objetivo definido. necesidad de información

Se debe tener cuidado al determinar los atributos a medir. Es impracticable, costoso y contraproducente medir demasiados atributos o los incorrectos. Además de los costos de medir, analizar y evaluar numerosos atributos, existe la posibilidad de que los problemas clave se oculten o pasen por alto por completo.

Hay dos tipos genéricos de medidas:

- h) mediciones del desempeño, que expresan los resultados planificados en términos de las características de la actividad planificada, como el número de empleados, el logro de hitos o el grado en que se implementan los controles de seguridad de la información; y
- i) medidas de eficacia, que expresan el efecto que la realización de las actividades planificadas tiene sobre los objetivos de seguridad de la información de la organización.

Puede ser apropiado identificar y asignar funciones distintivas a quienes participan en el seguimiento, la medición, el análisis y la evaluación. Esos roles pueden ser cliente de medición, planificador de medición, revisor de medición, propietario de información, recopilador de información, analista de información y comunicador de información de entrada o salida de evaluación (ver ISO/IEC 27004:2016, 6.5).

Las responsabilidades de seguimiento y medición y las de análisis y evaluación a menudo se asignan a personas distintas a las que se les exige una competencia diferente.

Otra información

El seguimiento, la medición, el análisis y la evaluación son fundamentales para el éxito de un SGSI eficaz. Hay una serie de cláusulas en ISO/IEC 27001 que requieren explícitamente la determinación de la eficacia de algunas actividades. Por ejemplo, ISO/IEC 27001:2013, 6.1.1 e), 7.2 c) o 10.1 d).

Se puede encontrar más información en ISO/IEC 27004, que proporciona orientación sobre el cumplimiento de los requisitos de ISO/IEC 27001:2013, 9.1. En particular, amplía todos los conceptos mencionados anteriormente, como roles y responsabilidades, y formas, y da numerosos ejemplos.

9.2 Auditoría interna

Actividad requerida

La organización realiza auditorías internas para proporcionar información sobre la conformidad del SGSI con los requisitos.

Explicación

La evaluación de un SGSI a intervalos planificados por medio de auditorías internas proporciona seguridad sobre el estado del SGSI a la alta dirección. La auditoría se caracteriza por una serie de principios: integridad; presentación justa; debido cuidado profesional; confidencialidad; independencia; y enfoque basado en la evidencia (ver ISO 19011).

Las auditorías internas proporcionan información sobre si el SGSI se ajusta a los requisitos propios de la organización para su SGSI, así como a los requisitos de la norma ISO/IEC 27001. Los requisitos propios de la organización incluyen:

- a) los requisitos establecidos en la política y los procedimientos de seguridad de la información;
- b) requisitos producidos por el marco para establecer objetivos de seguridad de la información, incluyendo resultados del proceso de tratamiento de riesgos;
- c) requisitos legales y contractuales; y
- d) requisitos sobre la información documentada.

Los auditores también evalúan si el SGSI se implementa y mantiene de manera efectiva.

Un programa de auditoría describe el marco general para un conjunto de auditorías, planificadas para plazos específicos y dirigidas a propósitos específicos. Esto es diferente de un plan de auditoría, que describe las actividades y arreglos para una auditoría específica. Los criterios de auditoría son un conjunto de políticas, procedimientos o requisitos utilizados como referencia con la que se compara la evidencia de auditoría, es decir, los criterios de auditoría describen lo que el auditor espera que esté implementado.

ISO/IEC 27003:2017(E)

Una auditoría interna puede identificar no conformidades, riesgos y oportunidades. Las no conformidades se gestionan de acuerdo con los requisitos de 10.1. Los riesgos y oportunidades se gestionan de acuerdo con los requisitos de 4.1 y 6.1.

Se requiere que la organización conserve información documentada sobre los programas de auditoría y los resultados de la auditoría.

Guía

Gestión de un programa de auditoría

Un programa de auditoría define la estructura y las responsabilidades para planificar, realizar, informar y dar seguimiento a las actividades de auditoría individuales. Como tal, debe garantizar que las auditorías realizadas sean adecuadas, tengan el alcance correcto, minimicen el impacto en las operaciones de la organización y mantengan la calidad necesaria de las auditorías. Un programa de auditoría también debe garantizar la competencia de los equipos de auditoría, el mantenimiento adecuado de los registros de auditoría y el seguimiento y la revisión de las operaciones, los riesgos y la eficacia de las auditorías. Además, un programa de auditoría debe garantizar que el SGSI (es decir, todos los procesos, funciones y controles relevantes) sea auditado dentro de un marco de tiempo específico. Finalmente, un programa de auditoría debe incluir información documentada sobre los tipos, la duración, las ubicaciones y el cronograma de las auditorías.

El alcance y la frecuencia de las auditorías internas deben basarse en el tamaño y la naturaleza de la organización, así como en la naturaleza, la funcionalidad, la complejidad y el nivel de madurez del SGSI (auditoría basada en el riesgo).

La eficacia de los controles implementados debe examinarse dentro del alcance de las auditorías internas.

Se debe diseñar un programa de auditoría para garantizar la cobertura de todos los controles necesarios y debe incluir la evaluación de la eficacia de los controles seleccionados a lo largo del tiempo. Los controles clave (según el programa de auditoría) deben incluirse en cada auditoría, mientras que los controles implementados para gestionar riesgos más bajos pueden auditarse con menos frecuencia.

El programa de auditoría también debe considerar que los procesos y controles deben haber estado en funcionamiento durante algún tiempo para permitir la evaluación de evidencia adecuada.

Las auditorías internas relacionadas con un SGSI se pueden realizar de manera efectiva como parte de, o en colaboración con, otras auditorías internas de la organización. El programa de auditoría puede incluir auditorías relacionadas con uno o más estándares de sistemas de gestión, realizadas por separado o en combinación.

Un programa de auditoría debe incluir información documentada sobre: criterios de auditoría, métodos de auditoría, selección de equipos de auditoría, procesos para manejar la confidencialidad, seguridad de la información, disposiciones de salud y seguridad para los auditores y otros asuntos similares.

Competencia y evaluación de los auditores

Con respecto a la competencia y evaluación de los auditores, la organización debería:

- e) identificar los requisitos de competencia de sus auditores;
- f) seleccionar auditores internos o externos con la competencia adecuada;
- g) contar con un proceso para monitorear el desempeño de los auditores y equipos de auditoría; y
- h) incluir personal en los equipos de auditoría interna que tengan conocimientos adecuados sobre seguridad de la información y específicos del sector.

Los auditores deben seleccionarse teniendo en cuenta que deben ser competentes, independientes y adecuadamente capacitados.

La selección de auditores internos puede ser difícil para las empresas más pequeñas. Si los recursos y la competencia necesarios no están disponibles internamente, se deben nombrar auditores externos. Cuando las organizaciones utilizan auditores externos, deben asegurarse de que hayan adquirido suficiente conocimiento sobre el contexto de la organización. Esta información debe ser suministrada por personal interno.

Las organizaciones deben considerar que los empleados internos que actúan como auditores internos pueden realizar auditorías detalladas teniendo en cuenta el contexto de la organización, pero es posible que no tengan suficiente conocimiento sobre cómo realizar auditorías.

Luego, las organizaciones deben reconocer las características y las posibles deficiencias de los auditores internos frente a los externos y establecer equipos de auditoría adecuados con el conocimiento y la competencia necesarios.

Realización de la auditoría

Al realizar la auditoría, el líder del equipo de auditoría debe preparar un plan de auditoría considerando los resultados de auditorías anteriores y la necesidad de dar seguimiento a las no conformidades y riesgos inaceptables informados anteriormente. El plan de auditoría debe conservarse como información documentada y debe incluir los criterios, el alcance y los métodos de la auditoría.

El equipo de auditoría debe revisar:

- adecuación y eficacia de los procesos y controles determinados;
- cumplimiento de los objetivos de seguridad de la información;
- cumplimiento de los requisitos definidos en ISO/IEC 27001:2013, cláusulas 4 a 10;
- cumplimiento de los requisitos de seguridad de la información propios de la organización;
- consistencia de la Declaración de Aplicabilidad contra el resultado del riesgo de seguridad de la información proceso de tratamiento;
- coherencia del plan de tratamiento de riesgos de seguridad de la información real con los riesgos evaluados identificados y los criterios de aceptación del riesgo;
- relevancia (considerando el tamaño y la complejidad de la organización) de los aportes de revisión de la dirección y salidas; y
- impactos de los resultados de la revisión por la dirección (incluidas las necesidades de mejora) en la organización.

El alcance y la confiabilidad del monitoreo disponible sobre la efectividad de los controles producidos por el SGSI (ver 9.1) puede permitir que los auditores reduzcan sus propios esfuerzos de evaluación, siempre que tengan confirmó la efectividad de los métodos de medición.

Si el resultado de la auditoría incluye no conformidades, el auditado debe preparar un plan de acción para cada no conformidad que se acordará con el líder del equipo de auditoría. Un plan de acción de seguimiento generalmente incluye:

- i) descripción de la no conformidad detectada;
- j) descripción de la(s) causa(s) de la no conformidad;
- k) descripción de la corrección a corto plazo y la acción correctiva a más largo plazo para eliminar una no conformidad detectada dentro de un marco de tiempo definido; y
- l) las personas responsables de la ejecución del plan.

Los informes de auditoría, con los resultados de la auditoría, deben distribuirse a la alta dirección.

Los resultados de las auditorías anteriores deben revisarse y el programa de auditoría debe ajustarse para administrar mejor las áreas que experimentan mayores riesgos debido a la no conformidad.

Otra información

Se puede encontrar más información en ISO 19011, que proporciona una guía general sobre la auditoría de sistemas de gestión, incluidos los principios de auditoría, la gestión de un programa de auditoría y la realización de auditorías de sistemas de gestión. También proporciona orientación sobre la evaluación de la competencia de las personas o grupos de personas involucradas en la auditoría, incluida la persona que gestiona el programa de auditoría, los auditores y los equipos de auditoría.

ISO/IEC 27003:2017(E)

Además, además de la guía contenida en ISO 19011, se puede encontrar más información en:

- a) ISO/IEC 270071), que proporciona orientación específica sobre la gestión de un programa de auditoría de SGSI, sobre realizar las auditorías y sobre la competencia de los auditores del SGSI; y
- b) ISO/IEC 270081), que brinda orientación sobre la evaluación de los controles de seguridad de la información.

9.3 Revisión por la dirección

Actividad requerida

La alta dirección revisa el SGSI a intervalos planificados.

Explicación

El propósito de la revisión por la dirección es garantizar la idoneidad, adecuación y eficacia continuas del SGSI. La idoneidad se refiere a la alineación continua con los objetivos de la organización. La adecuación y la eficacia se refieren a un diseño adecuado y la integración organizativa del SGSI, así como la implementación efectiva de procesos y controles que son impulsados por el SGSI.

En general, la revisión por la dirección es un proceso que se lleva a cabo en varios niveles de la organización. Estas actividades pueden variar desde reuniones de unidades organizacionales diarias, semanales o mensuales hasta simples discusiones de informes. La alta dirección es, en última instancia, responsable de la revisión por la dirección, con aportaciones de todos los niveles de la organización.

Guía

La alta dirección debe exigir y revisar periódicamente la presentación de informes sobre el rendimiento del SGSI.

Hay muchas maneras en que la gerencia puede revisar el SGSI, como recibir y revisar mediciones e informes, comunicación electrónica, actualizaciones verbales. Las entradas clave son los resultados de las medidas de seguridad de la información como se describe en 9.1 y los resultados de las auditorías internas descritas en 9.2 y los resultados de la evaluación de riesgos y el estado del plan de tratamiento de riesgos. Al revisar los resultados de la evaluación de riesgos de seguridad de la información y el estado del plan de tratamiento de riesgos de seguridad de la información, la gerencia debe confirmar que los riesgos residuales cumplen con los criterios de aceptación de riesgos y que el plan de tratamiento de riesgos aborda todos los riesgos relevantes y sus opciones de tratamiento de riesgos.

Todos los aspectos del SGSI deben ser revisados por la gerencia a intervalos planificados, al menos una vez al año, mediante el establecimiento de cronogramas y puntos de agenda adecuados en las reuniones de la gerencia. Los SGSI nuevos o menos maduros deben ser revisados con mayor frecuencia por la gerencia para impulsar una mayor eficacia.

La agenda de la revisión por la dirección debe abordar los siguientes temas:

- a) estado de las acciones de revisiones de gestión anteriores;
- b) cambios en cuestiones externas e internas (ver 4.1) que son relevantes para el SGSI;
- c) retroalimentación sobre el desempeño de la seguridad de la información, incluidas las tendencias, en:
 - 1) no conformidades y acciones correctivas;
 - 2) resultados de monitoreo y medición;
 - 3) resultados de la auditoría; y
 - 4) cumplimiento de los objetivos de seguridad de la información.
- d) comentarios de las partes interesadas, incluidas sugerencias de mejora, solicitudes de cambio y quejas;

1) Segunda edición en preparación.

- e) resultados de las evaluaciones de riesgos de seguridad de la información y estado del tratamiento de riesgos de seguridad de la información plan; y
- f) oportunidades para la mejora continua, incluidas las mejoras en la eficiencia tanto del SGSI como de los controles de seguridad de la información.

Los aportes a la revisión por la dirección deben tener el nivel de detalle adecuado, de acuerdo con los objetivos establecidos para la dirección involucrada en la revisión. Por ejemplo, la alta dirección debe evaluar solo un resumen de todos los elementos, de acuerdo con los objetivos de seguridad de la información o los objetivos de alto nivel.

Los resultados del proceso de revisión por la dirección deben incluir decisiones relacionadas con oportunidades de mejora continua y cualquier necesidad de cambios en el SGSI. También pueden incluir pruebas de decisiones relativas a:

- g) cambios en la política y los objetivos de seguridad de la información, por ejemplo, impulsados por cambios en los asuntos internos y requerimientos de las partes interesadas;
- h) cambios de los criterios de aceptación del riesgo y los criterios para realizar el riesgo de seguridad de la información evaluaciones (ver [6.1.2](#));
- i) acciones, si es necesario, luego de la evaluación del desempeño de la seguridad de la información;
- j) cambios de recursos o presupuesto del SGSI;
- k) plan de tratamiento de riesgos de seguridad de la información actualizado o Declaración de Aplicabilidad; y
- l) las mejoras necesarias de las actividades de seguimiento y medición.

Se requiere información documentada de las revisiones de la dirección. Debe conservarse para demostrar que se han considerado (al menos) todas las áreas enumeradas en ISO/IEC 27001, incluso cuando se decide que no es necesaria ninguna acción.

Cuando se realizan varias revisiones de gestión en diferentes niveles de la organización, deben vincularse entre sí de manera adecuada.

Otra información

Ninguna otra información.

10 Mejora

10.1 No conformidad y acción correctiva

Actividad requerida

La organización reacciona a las no conformidades, las evalúa y toma correcciones y acciones correctivas si es necesario.

Explicación

Una no conformidad es un incumplimiento de un requisito del SGSI. Los requisitos son necesidades o expectativas establecidas, implícitas u obligatorias. Existen varios tipos de no conformidades tales como:

- a) incumplimiento de un requisito (total o parcialmente) de ISO/IEC 27001 en el SGSI;
- b) la falta de implementación correcta o conformidad con un requisito, regla o control establecido por el SGSI; y
- c) el incumplimiento parcial o total de los requisitos legales, contractuales o acordados con el cliente.

Las no conformidades pueden ser por ejemplo:

- d) personas que no se comportan como lo esperan los procedimientos y políticas;

ISO/IEC 27003:2017(E)

e) proveedores que no proporcionen los productos o servicios acordados;

f) proyectos que no entregan los resultados esperados; y

g) controles que no funcionan según el diseño.

Las no conformidades pueden ser reconocidas por:

h) deficiencias de las actividades realizadas en el ámbito del sistema de gestión;

i) controles ineficaces que no se remedian adecuadamente;

j) análisis de incidentes de seguridad de la información, mostrando el incumplimiento de un requisito del SGSI;

k) quejas de los clientes;

l) alertas de usuarios o proveedores;

m) resultados de seguimiento y medición que no cumplen los criterios de aceptación; y

n) objetivos no alcanzados.

Las correcciones tienen como objetivo abordar la no conformidad de inmediato y lidiar con sus consecuencias (ISO/IEC 27001:2013, 10.1 a)).

Las acciones correctivas tienen como objetivo eliminar la causa de una no conformidad y prevenir la recurrencia (ISO/IEC 27001:2013, 10.1 b) a g)).

Tenga en cuenta que "según corresponda" (ISO/IEC 27001:2013, 10.1 a)) significa que si se puede tomar una acción para controlar y corregir una no conformidad, entonces es necesario tomarla.

Guía

Los incidentes de seguridad de la información no implican necesariamente que exista una no conformidad, pero pueden ser un indicador de una no conformidad. La auditoría interna y externa y las quejas de los clientes son otras fuentes importantes que ayudan a identificar las no conformidades.

La reacción a la no conformidad debe basarse en un proceso de manejo definido. El proceso debe incluir:

- identificar el alcance y el impacto de la no conformidad;
- decidir sobre las correcciones para limitar el impacto de la no conformidad. Las correcciones pueden incluir cambiar a estados anteriores, a prueba de fallas u otros estados apropiados. Se debe tener cuidado de que las correcciones no empeoren la situación;
- comunicarse con el personal pertinente para garantizar que se lleven a cabo las correcciones;
- llevar a cabo las correcciones según lo decidido;
- monitorear la situación para asegurar que las correcciones hayan tenido el efecto previsto y no hayan producido efectos secundarios no deseados;
- actuar más para corregir la no conformidad si aún no se ha remediado; y
- comunicarse con otras partes interesadas relevantes, según corresponda.

Como resultado general, el proceso de manejo debería conducir a un estado gestionado con respecto a la no conformidad y las consecuencias asociadas. Sin embargo, las correcciones por sí solas no necesariamente evitarán la recurrencia de la no conformidad.

Las acciones correctivas pueden ocurrir después o en paralelo con las correcciones. Los siguientes pasos del proceso deben ser tomados:

1. decidir si es necesario llevar a cabo una acción correctiva, de acuerdo con los criterios establecidos (por ejemplo, impacto de la no conformidad, repetitividad);
2. revisión de la no conformidad, considerando:
 - si se han registrado no conformidades similares;
 - todas las consecuencias y efectos colaterales causados por la no conformidad; y
 - las correcciones realizadas.
3. realizar un análisis profundo de la causa de la no conformidad, considerando:
 - qué salió mal, el desencadenante específico o la situación que condujo a la no conformidad (p. ej., errores determinados por personas, métodos, procesos o procedimientos, herramientas de hardware o software, mediciones incorrectas, entorno); y
 - patrones y criterios que pueden ayudar a identificar situaciones similares en el futuro.
4. realizar un análisis de las posibles consecuencias sobre el SGSI, considerando:
 - si existen no conformidades similares en otras áreas, por ejemplo, utilizando los patrones y criterios encontrados durante el análisis de la causa; y
 - si otras áreas coinciden con los patrones o criterios identificados, de modo que es solo cuestión de tiempo antes de que ocurra una no conformidad similar.
5. determinar las acciones necesarias para corregir la causa, evaluando si son proporcionales a las consecuencias e impacto de la no conformidad, y verificando que no tengan efectos secundarios que puedan conducir a otras no conformidades o nuevos riesgos significativos para la seguridad de la información;
6. planificar las acciones correctivas, dando prioridad, si es posible, a las áreas donde hay mayor probabilidad de recurrencia y consecuencias más significativas de la no conformidad. La planificación debe incluir una persona responsable de una acción correctiva y una fecha límite para la implementación;
7. implementar las acciones correctivas de acuerdo con el plan; y
8. evaluar las acciones correctivas para determinar si realmente han manejado la causa de la no conformidad y si han evitado que ocurran las no conformidades relacionadas. Esta evaluación debe ser imparcial, basada en evidencia y documentada. También se debe comunicar a los roles apropiados y a las partes interesadas.

Como resultado de las correcciones y acciones correctivas, es posible que se identifiquen nuevas oportunidades de mejora. Estos deben ser tratados en consecuencia (ver [10.2](#)).

Se requiere conservar suficiente información documentada para demostrar que la organización ha actuado adecuadamente para abordar la no conformidad y se ha ocupado de las consecuencias relacionadas.

Todos los pasos significativos de la gestión de no conformidades (a partir del descubrimiento y las correcciones) y, si se iniciaron, la gestión de acciones correctivas (análisis de causas, revisión, decisión sobre la implementación de acciones, revisión y decisiones de cambio tomadas para el propio SGSI) deben documentarse. También se requiere que la información documentada incluya evidencia de si las acciones tomadas han logrado o no los efectos previstos.

Algunas organizaciones mantienen registros para el seguimiento de no conformidades y acciones correctivas. Puede haber más de un registro (por ejemplo, uno para cada área funcional o proceso) y en diferentes soportes (papel, archivo, solicitud, etc.). Si este es el caso, entonces deben establecerse y controlarse como información documentada y deben permitir una revisión integral de todas las no conformidades y acciones correctivas para garantizar la evaluación correcta de la necesidad de acciones.

Otra información

ISO/IEC 27003:2017(E)

ISO/IEC 27001 no establece explícitamente ningún requisito para la "acción preventiva". Esto se debe a que uno de los propósitos clave de un sistema de gestión formal es actuar como una herramienta preventiva. En consecuencia, el texto común utilizado en las normas del sistema de gestión ISO requiere una evaluación de los "problemas externos e internos de la organización que son relevantes para su propósito y que afectan su capacidad para lograr los resultados previstos" en 4.1, y para "determinar" el riesgos y oportunidades que deben abordarse para: garantizar que el SGSI pueda lograr los resultados previstos; prevenir o reducir los efectos no deseados; y lograr la mejora continua." en 6.1. Se considera que estos dos conjuntos de requisitos cubren el concepto de "acción preventiva", y también adoptan una visión más amplia que analiza los riesgos y las oportunidades.

10.2 Mejora continua

Actividad requerida

La organización mejora continuamente la idoneidad, adecuación y eficacia del SGSI.

Explicación

Las organizaciones y sus contextos nunca son estáticos. Además, los riesgos para los sistemas de información y las formas en que pueden verse comprometidos están evolucionando rápidamente. Finalmente, ningún SGSI es perfecto; siempre hay una forma de mejorar, incluso si la organización y su contexto no están cambiando.

Como ejemplo de mejoras no vinculadas con no conformidades o riesgos, la evaluación de un elemento del SGSI (en términos de idoneidad, adecuación y eficacia) puede mostrar que excede los requisitos del SGSI o carece de eficiencia. Si es así, entonces puede haber una oportunidad de mejorar el SGSI cambiando el elemento evaluado.

Un enfoque sistemático que utilice la mejora continua conducirá a un SGSI más efectivo, lo que mejorará la seguridad de la información de la organización. La gestión de la seguridad de la información dirige las actividades operativas de la organización para evitar ser demasiado reactiva, es decir, que la mayoría de los recursos se utilicen para encontrar problemas y abordarlos. El SGSI está trabajando sistemáticamente a través de la mejora continua para que la organización pueda tener un enfoque más proactivo. La alta dirección puede establecer objetivos para la mejora continua, por ejemplo, mediante mediciones de eficacia, coste o madurez del proceso.

Como consecuencia, la organización trata su SGSI como una parte viva, en evolución y de aprendizaje de las operaciones comerciales. Para que el SGSI se mantenga al día con los cambios, se evalúa regularmente con respecto a su adecuación al propósito, efectividad y alineación con los objetivos de la organización. Nada se debe dar por sentado, y nada se debe considerar como 'fuera de los límites' simplemente porque era lo suficientemente bueno en el momento en que se implementó.

Guía

La mejora continua del SGSI debe implicar que el propio SGSI y todos sus elementos se evalúen teniendo en cuenta las cuestiones internas y externas (4.1), los requisitos de las partes interesadas (4.2) y los resultados de la evaluación del desempeño (Cláusula 9). La evaluación debe incluir un análisis de:

- a) la idoneidad del SGSI, considerando si los problemas externos e internos, los requisitos de las partes interesadas, los objetivos de seguridad de la información establecidos y los riesgos de seguridad de la información identificados se abordan adecuadamente mediante la planificación e implementación del SGSI y los controles de seguridad de la información;
- b) la adecuación del SGSI, considerando si los procesos del SGSI y los controles de seguridad de la información son compatibles con los propósitos, actividades y procesos generales de la organización; y
- c) la efectividad del SGSI, considerando si se logran los resultados previstos del SGSI, se cumplen los requisitos de las partes interesadas, se gestionan los riesgos de seguridad de la información para cumplir con los objetivos de seguridad de la información, se gestionan las no conformidades, mientras que los recursos necesarios para la el establecimiento, la implementación, el mantenimiento y la mejora continua del SGSI son proporcionales a esos resultados.

La evaluación también puede incluir un análisis de la eficiencia del SGSI y sus elementos, considerando si su uso de los recursos es apropiado, si existe el riesgo de que la falta de eficiencia pueda conducir a la pérdida de efectividad o si hay oportunidades para aumentar la eficiencia. .

Las oportunidades de mejora también se pueden identificar al gestionar las no conformidades y las acciones correctivas.

Una vez que se identifican las oportunidades de mejora, la organización debería, de acuerdo con [6.1.1](#): 

d) evaluarlos para establecer si vale la pena seguirlos;

e) determinar los cambios al SGSI y sus elementos para lograr la mejora;

f) planificar e implementar las acciones para abordar las oportunidades asegurando que se obtengan los beneficios, y no se producen no conformidades; y

g) evaluar la eficacia de las acciones.

Estas acciones deben considerarse como un subconjunto de acciones para abordar los riesgos y oportunidades descritos en [6.1.1](#).

Otra información

Ninguna otra información.

Anexo A (informativo)

Marco político

El Anexo A brinda orientación sobre la estructura de la documentación que incluye la política de seguridad de la información.

En general, una política es una declaración de intenciones y dirección de una organización expresada formalmente por su alta dirección (ver ISO/IEC 27000:2016, 2.84).

El contenido de una política orienta las acciones y decisiones relativas al tema de la política.

Una organización puede tener varias políticas; uno para cada una de las áreas de actividad que es importante para la organización. Algunas políticas son independientes entre sí, mientras que otras políticas tienen una relación jerárquica.

Por lo general, una organización tiene una política general, por ejemplo, un código de conducta, en el nivel más alto de la jerarquía de políticas. La política general está respaldada por otras políticas que abordan diferentes temas y pueden ser aplicables a áreas o funciones específicas de la organización. La política de seguridad de la información es una de estas políticas específicas.

La política de seguridad de la información está respaldada por una variedad de políticas de temas específicos relacionados con aspectos de la seguridad de la información. Varios de estos se analizan en ISO/IEC 27002, por ejemplo, la política de seguridad de la información puede estar respaldada por políticas relacionadas con el control de acceso, clasificación (y manejo) de la información, seguridad física y ambiental, temas orientados al usuario final, entre otros. Se pueden agregar capas adicionales de políticas. Este arreglo se muestra en [la Figura A.1](#). Tenga en cuenta que algunas organizaciones utilizan otros términos para los documentos de políticas de temas específicos, como "estándares", "directivas" o "reglas".

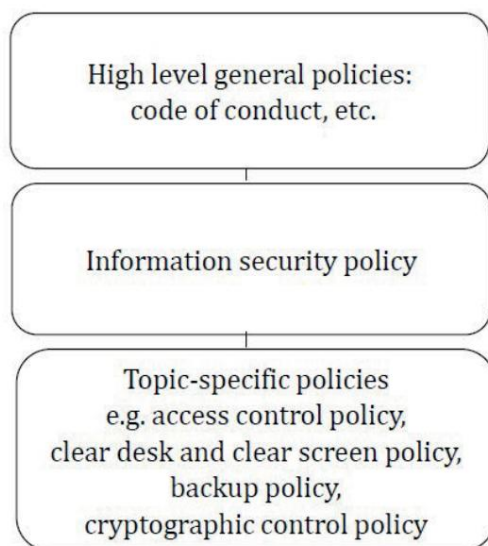


Figura A.1 — Jerarquía de políticas

ISO/IEC 27001 requiere que las organizaciones tengan una política de seguridad de la información. Sin embargo, no especifica ninguna relación particular entre esta política y otras políticas de la organización.

El contenido de las políticas se basa en el contexto en el que opera una organización. Específicamente, se debe considerar lo siguiente al desarrollar cualquier política dentro del marco de políticas:

1. las metas y objetivos de la organización;
2. estrategias adoptadas para lograr los objetivos de la organización;
3. la estructura y los procesos adoptados por la organización;
4. finalidades y objetivos asociados al tema de la política;
5. los requisitos de las políticas de nivel superior relacionadas; y
6. el grupo objetivo al que se dirigirá la política.

Esto se muestra en [la Figura A.2](#).

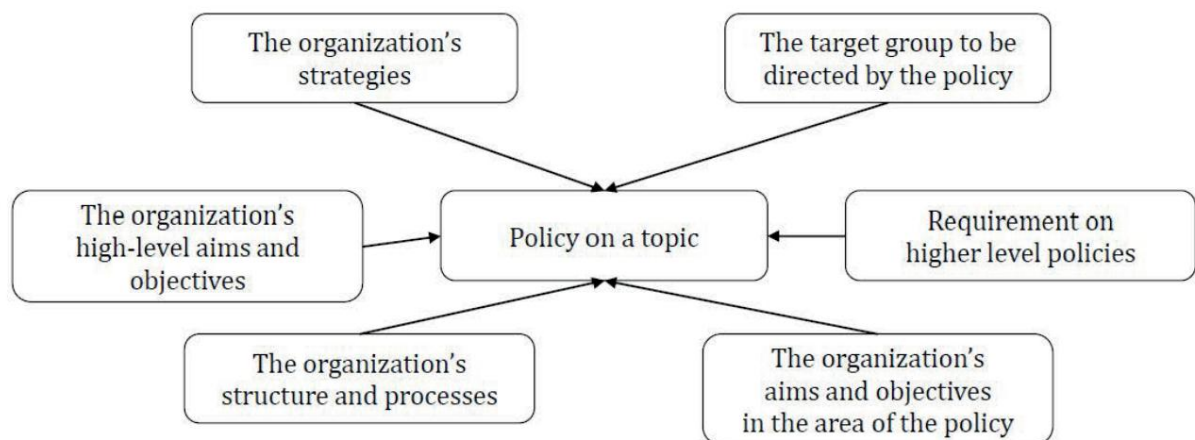


Figura A.2 — Entradas para el desarrollo de una política

Las políticas pueden tener la siguiente estructura:

- a) **Administrativo:** título de la política, versión, fechas de publicación/validez, historial de cambios, propietario(s) y aprobador(es), clasificación, destinatario, etc.;
- b) **Resumen de la política:** una descripción general de una o dos oraciones. (Esto a veces se puede fusionar con el introducción.);
- c) **Introducción** – una breve explicación del tema de la política;
- d) **Alcance:** describe aquellas partes o actividades de una organización que se ven afectadas por la política. Si relevante, la cláusula de alcance enumera otras políticas que son compatibles con la política;
- e) **Objetivos:** describe la intención de la política;
- f) **Principios** - describe las reglas relativas a las acciones y decisiones para el logro de los objetivos. En algunos casos, puede ser útil identificar los procesos clave asociados con el tema de la política y luego las reglas para operar los procesos;
- g) **Responsabilidades:** describe quién es responsable de las acciones para cumplir con los requisitos de la política. En algunos casos, esto puede incluir una descripción de los arreglos organizativos, así como las responsabilidades y la autoridad de las personas con roles designados;

ISO/IEC 27003:2017(E)

- h) ~~Resultados clave~~: describe los resultados comerciales si se cumplen los objetivos. En algunos casos, esto puede fusionarse con los objetivos;
- i) ~~Políticas relacionadas~~: describe otras políticas relevantes para el logro de los objetivos, generalmente por proporcionar detalles adicionales sobre temas específicos; y
- j) ~~Requisitos de la póliza~~: describe los requisitos detallados de la póliza.

El contenido de la política se puede organizar de varias maneras. Por ejemplo, las organizaciones que ponen énfasis en las funciones y responsabilidades pueden simplificar la descripción de los objetivos y aplicar los principios específicamente a la descripción de las responsabilidades.

Bibliografía

- [1] ISO 19011, Directrices para la auditoría de sistemas de gestión
- [2] ISO/IEC 27002:2013, Tecnología de la información. Técnicas de seguridad. Código de prácticas para los controles de seguridad de la información.
- [3] ISO/IEC 27003:2010, Tecnología de la información. Técnicas de seguridad. Guía para la implementación del sistema de gestión de la seguridad de la información.
- [4] ISO/IEC 27004:2016, Tecnología de la información. Técnicas de seguridad. Gestión de la seguridad de la información. Seguimiento, medición, análisis y evaluación.
- [5] ISO/IEC 27005, Tecnología de la información. Técnicas de seguridad. Gestión de riesgos de seguridad de la información.
- [6] ISO/IEC 270072), Tecnología de la información. Técnicas de seguridad. Directrices para la auditoría de los sistemas de gestión de la seguridad de la información.
- [7] ISO/IEC/TS 270082), Tecnología de la información. Técnicas de seguridad. Directrices para la evaluación de los controles de seguridad de la información.
- [8] ISO 30301, Información y documentación. Sistemas de gestión de registros. Requisitos.
- [9] ISO 31000, Gestión de riesgos — Principios y directrices

ISO/IEC 27003:2017(E)